

Including insider threats into risk management through Bayesian threat graph networks

Nicola d'Ambrosio, Gaetano Perrone ^{*}, Simon Pietro Romano

University of Napoli Federico II, Department of Electrical Engineering and Information Technology, Via Claudio 21, 80125 Napoli, Italy

ARTICLE INFO

Keywords:

Insider threats
Risk assessment
Risk management
Bayesian attack graphs
Attack graphs
Data security

ABSTRACT

Cybersecurity incidents do represent a serious danger for companies. In fact, the number of cyber crimes is exponentially growing in a scenario where the global COVID-19 pandemic determined several conditions that have negatively affected companies' cyber-security posture. The adoption of risk management processes can help reduce security threats and mitigate both financial and reputation losses. In computer systems, it is crucial to relate security risks to the system infrastructure. Bayesian attack graph models can help reach such a goal. The approach is very effective as it allows to define the attack paths an attacker would perform against a specific network infrastructure. In this way, it is possible to construct a truthful representation of a company's security risks that cannot be obtained with other approaches. Still, Bayesian risk management approaches are usually based on advanced threats. Namely, those threats relate to vulnerabilities that can only be exploited by a skilled attacker. Although several works enrich the expressiveness of the proposed Bayesian model, current proposals do not provide insights into how it is possible to estimate security control costs, asset values, and threat probabilities for other types of threats. Furthermore, they do not take insider threats into consideration. This work shows that a risk management framework based on Bayesian Attack Graphs can be adapted to include a variety of threats, including those related to the insiders. We first extend an interesting work based on Bayesian Decision Networks to cover a broader range of threats. Then, we formalize several concepts, such as security control coverage and risk strategy, and show that our model can easily integrate insider threats when specific properties are defined. Finally, in order to address insider threats, we enrich the model with security controls that differ from the standard ones, such as technical IT training sessions and employee satisfaction surveys.

1. Introduction

IT Risk management is a fundamental activity in enterprise companies. Several approaches are commonly used to prioritize risks and define proper defensive risk strategies. One of the challenges in implementing risk assessment processes is the realization of a risk management strategy that addresses the real security risks of an IT system. A well-founded approach to model network attacks is the attack graph analysis (Phillips and Swiler, 1998). Through attack graphs, it is possible to effectively point out the exploits an attacker can perform against a system with vulnerabilities. Exploits occur based on satisfied preconditions. A relevant evolution of the approach is the Bayesian attack graph model (Frigault and Wang, 2008), which aims to integrate probabilistic models in order to estimate the likelihood of such preconditions. Bayesian attack graph models were adapted to

perform dynamic network risk assessments (Poolsappasit et al., 2012). These advancements have contributed to a more efficient and applicable risk assessment. Indeed, attack graphs make it possible to determine the risks associated with a particular asset. However, Bayesian attack graphs typically model cybersecurity threats based on exploiting either known or (in the case of more advanced models) unknown vulnerabilities through attacks performed by skilled technical intruders. One reason is related to the fact that such models usually adopt known vulnerability databases to define vulnerabilities, e.g., the National Vulnerability Database (NVD), as well as well-defined metrics, such as the Common Vulnerability Scoring System (CVSS), to estimate probabilities. However, these approaches are not able to use quantitative metrics to estimate probabilities of other kinds of threats, such as business email compromise or unintentional threats. The very few models which employ methods to evaluate other types of threats and define advanced

^{*} Corresponding author.

E-mail addresses: nicola.dambrosio2@unina.it (N. d'Ambrosio), gaetano.perrone@unina.it (G. Perrone), spromano@unina.it (S.P. Romano).

<https://doi.org/10.1016/j.cose.2023.103410>

Received 8 February 2023; Received in revised form 22 June 2023; Accepted 24 July 2023

Available online 28 July 2023

0167-4048/© 2023 Elsevier Ltd. All rights reserved.

security metrics, are typically based on heuristic approaches which underestimate important parameters. As an example, they do not take worldwide cybersecurity incident trends into account when estimating threats' probabilities.

In the above scenario, insider threats do represent a challenging class of menace, due to the increasing risk they pose to enterprise organizations.

The main contribution of this work is to show that it is possible to include insider threats in Bayesian risk management frameworks. Risk assessment is based on quantitative metrics for the definition of both security control costs and asset values. The underlying attack graph models allow for modeling the relationship between threat actors (internal and/or external) and assets. Threat probabilities are estimated by analyzing the number of occurrences of global security incident trends. We formulate an alternative model based on attack graphs that we name "threat graph" and show that it is possible to integrate insider threats into threat graphs by analyzing their relationships with assets and representing their enabling factors in terms of "initial threat nodes".

The remainder of this paper is structured as follows. Section 2 provides background information that is useful to better position our contribution. Section 3 analyzes several works that either investigate the insider threat topic or leverage the techniques we used to develop our framework, i.e., attack graphs and risk management processes. We will observe that many works address the problem of detecting insider threat activities, but few explore the application of risk management processes to defend companies against internal attackers. Furthermore, we sum up the model at the basis of our work, i.e., the Bayesian Risk Management Framework (BRMF), and show both its strengths and limitations. We then propose an enriched model that generalizes the vulnerability definition to include different types of threats. Section 4 delves deeper into the insider threat concept and shows that the proposed enriched framework can easily include insider threats. Section 5 shows a practical usage example of the proposed framework, while Section 6 summarizes the results and paves the ground to new research directions in the insider threats risk management landscape.

2. Background and motivation

In order to appreciate the details of our model, it is important to have a few preliminary notions. In this section, we summarize the attack graph concept and provide preliminary definitions that will help readers dig deeper into our model.

2.1. Attack graphs

This section illustrates the fundamental concepts associated with attack graphs. An excellent explanatory guide about attack graphs is provided by Zenitani (2023), attack graphs are fundamental models for performing network security analysis. An attack graph allows for the realization of causal relations between malicious events that occur in an enterprise network. The first graph-based system for network vulnerability analysis was proposed by Phillips and Swiler (1998), where they extended the fault-tree analysis (Kritzinger, 2017) in order to include cyclic structures. First attack graph representations were based on *state enumeration graphs*. In such representations, all vulnerabilities can be exploited, and this information is modeled with a state that can be either true or false. Therefore, if a network contains N computers and M vulnerabilities, the number of possible states is 2^{MN} , which might cause scalability issues. To overcome the problem, several works (Ammann et al., 2002; Jajodia et al., 2005) proposed an alternative approach called the "exploit-dependency graph". The representation is a bipartite directed graph composed of *exploit nodes* and *condition nodes* where each exploit node can only be connected to one or more condition nodes, and each condition node can only be connected to exploit nodes. Each condition node denotes a fact that can be a *precondition* that enables an

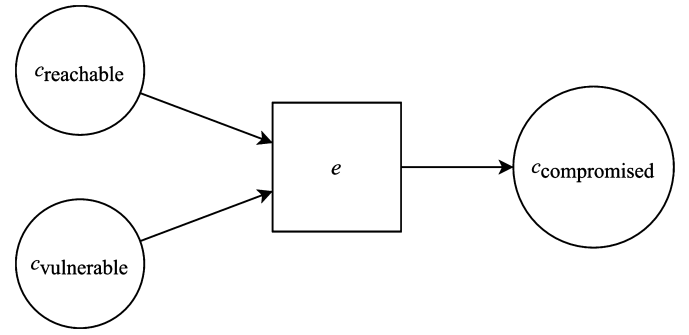


Fig. 1. Example of an attack graph.

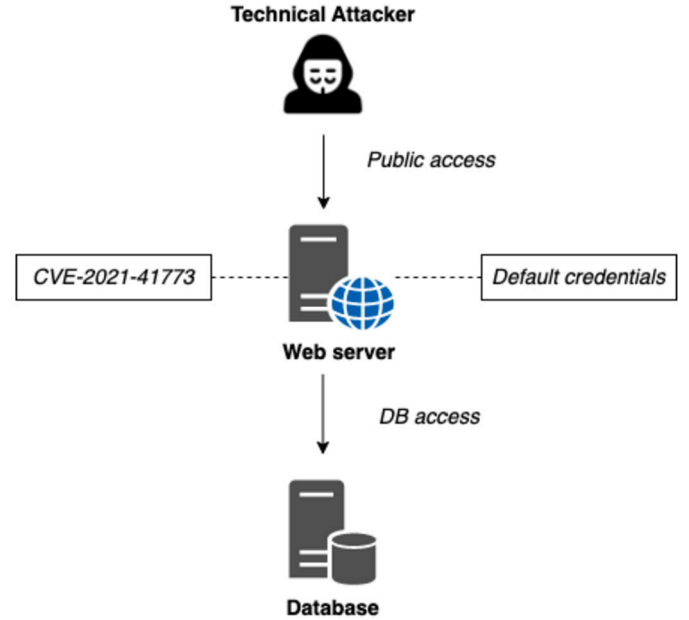


Fig. 2. A simple example of a vulnerable network.

exploit or a *postcondition* caused by an exploit. Hence, exploit nodes define causal relationships between condition nodes. It is possible to put these relationships into a graphical representation, as shown in Fig. 1. Exploit nodes are represented through rectangle nodes, while condition nodes are depicted with circle nodes. The relationships between conditions and exploits are modeled with edges, and the final representation is a directed bipartite graph.

Through attack graphs, it is possible to model network vulnerability scenarios easily. Fig. 2 shows a simple vulnerable network environment. In the example, the attacker has access to a public web server that is vulnerable to two critical remote command execution (RCE) vulnerabilities, i.e., "CVE-2021-41773" (NVD, 2021a) and "CVE-2021-44228" (NVD, 2021b). If the final attacker's goal is to obtain sensitive data located in the database, either of the two mentioned RCE vulnerabilities must be exploited.

In order to formalize the concept of attack graphs, several definitions can be found in the literature. A widely accepted one is that provided by Wang et al. (2006).

Definition 1 (Attack graph - Wang et al., 2006). Given a set of exploits E , a set of security conditions C where $E \cap C = \emptyset$, a *require* relation $R_r \subseteq C \times E$, and an *imply* relation $R_i \subseteq E \times C$, an *attack graph* G is the connected, directed graph $G = (E \cup C, R_r \cup R_i)$, where $(E \cup C)$ is the set of nodes and $(R_r \cup R_i)$ is the set of edges.

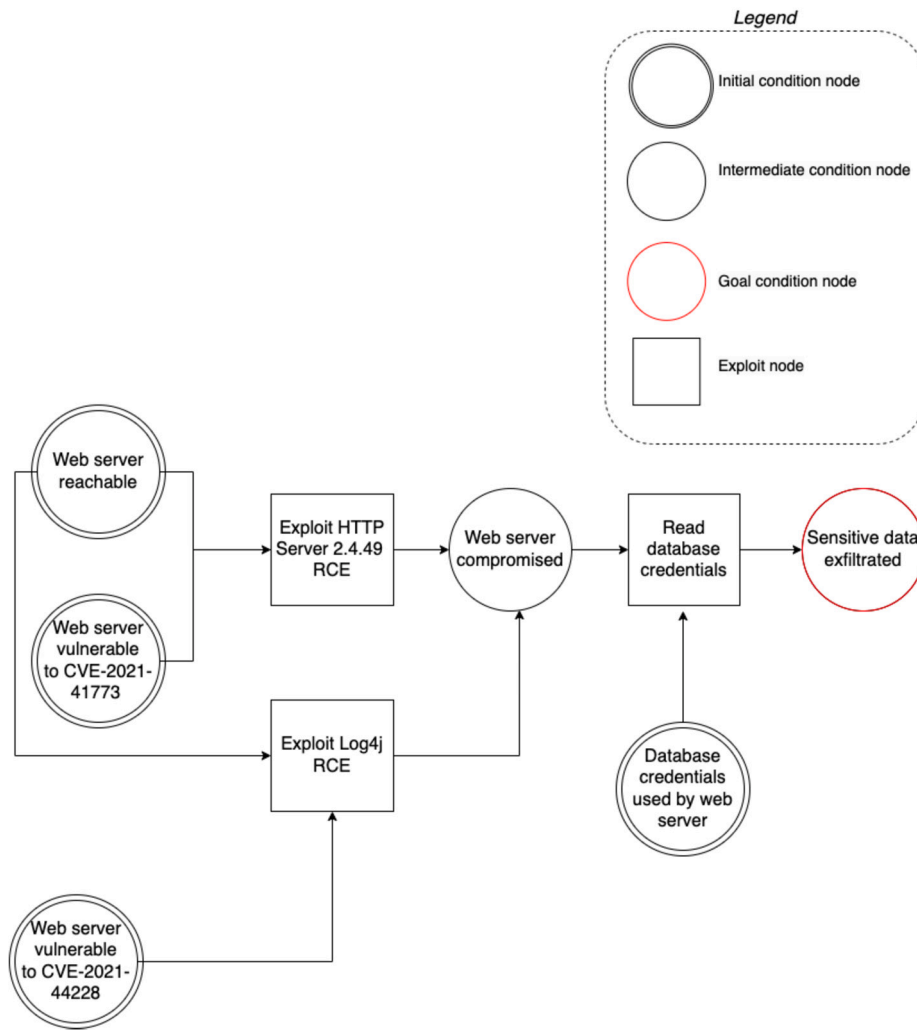


Fig. 3. Attack graph of the proposed example.

Zenitani (2023) includes another relevant concept in the definition, i.e., the *initial conditions*.

Definition 2 (*Initial conditions* - Zenitani, 2023). For each attack graph G , *initial conditions* refer to the subset $C_i \subseteq C$ composed of every condition $c \in C$ satisfying $\nexists e \in E$ such that $(e, c) \in R_i$.

In order to better fit our model with attack graphs, we introduce two further definitions:

Definition 3 (*Goal conditions*). For each attack graph G , *goal conditions* refer to the subset $C_g \subseteq C$ composed of every condition $c \in C$ satisfying $\nexists e \in E$ such that $(c, e) \in R_r$.

Goal conditions represent the final goals of the attacker.

Definition 4 (*Intermediate conditions*). For each attack graph G , *intermediate conditions* refer to the subset $C_m \subseteq C$ composed of every condition $c \in C$ such that $c \notin (C_g \cup C_i)$.

The related attack graph containing the three defined nodes is illustrated in Fig. 3. As it is possible to observe, the “web server compromised” condition is implied by two different exploits, and each exploit depends on other conditions.

2.1.1. Logical attack graph

Despite their effectiveness in modeling network attacks, attack graphs do not provide details about how to practically describe the conditions and exploits. From the previous example, it is essential to observe that the exploits can be performed when all the pre-conditions are satisfied. At the same time, a post-condition (such as “web server compromised”) can occur if at least one of the exploits succeeds. Hence, exploits can be considered as AND combinations of their pre-conditions, while post-conditions can be modeled as OR combinations of exploits.

Fig. 4 illustrates the concept applied to the example through logical AND and OR ports. These considerations addressed researchers toward the propositional logic. Conditions and models can be represented through a logic programming language, such as Datalog, i.e., the language proposed by Ceri et al. (1989). A Datalog program comprises a set of *rules* and *facts*. It accepts rules and facts and infers relationships in order to decide whether the assertion is True or False. In our example, we aim to model the final goal of the attacker, i.e., the exfiltration of sensitive data from the database. To the purpose, Datalog rules can be used for exploits, while Datalog facts can be used to model conditions.

An example of rules that can model the proposed exploits is illustrated in Listing 1.

Such rules only represent the attack model, but the attack graph of the example is realized when we define a set of facts.

Facts model the initial preconditions of the attack graph and generate post-conditions through the Datalog rules. In order to automate the realization of attack graphs, Ou et al. (2005) introduced MulVAL.

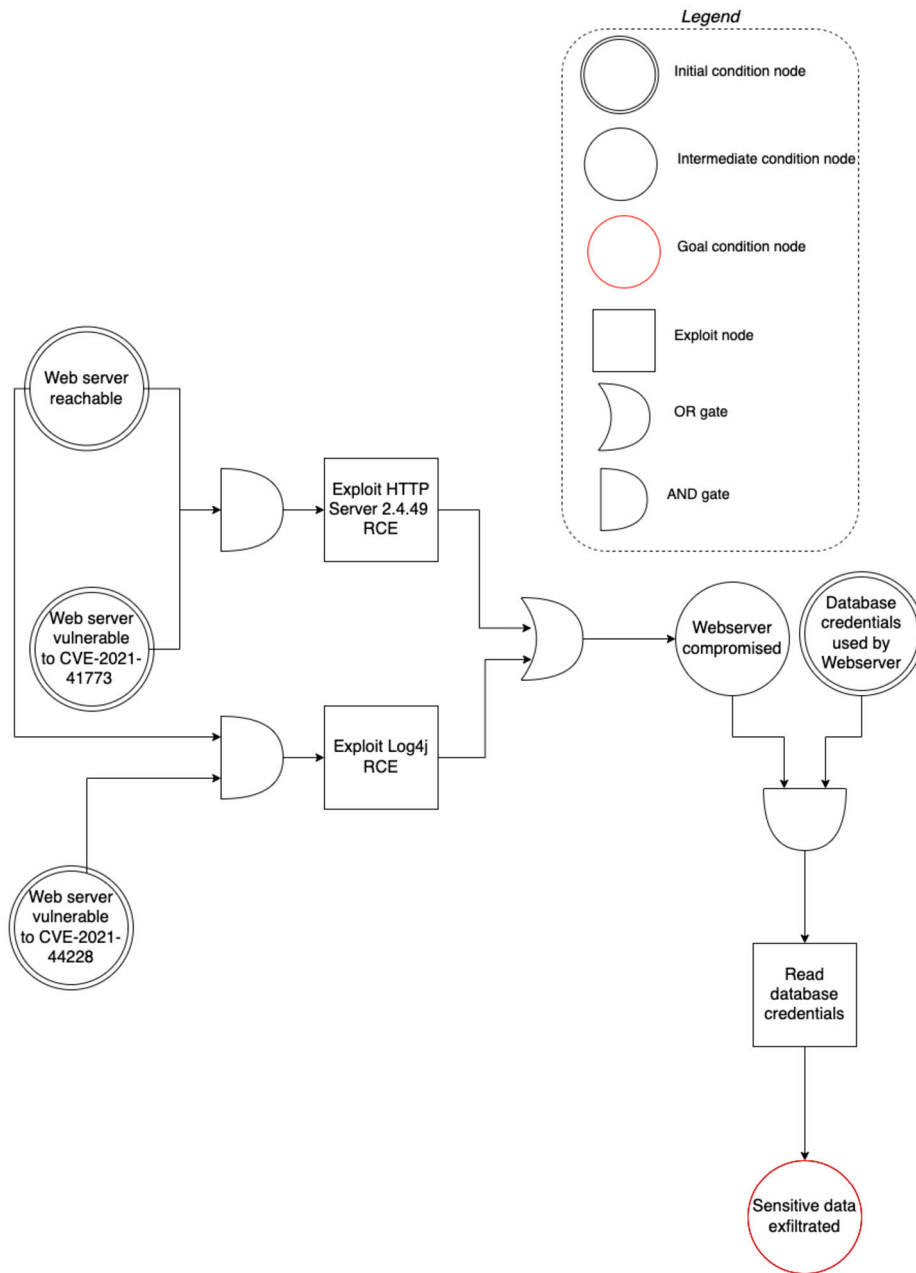


Fig. 4. Logical graph.

```

1 webserverCompromised(A, W) :- webserverReachable(A, W),
2   webserverVulnerableToRCE(W, V).
3
4 readDatabaseCredentials(A, D) :- webserverCompromised(A, W),
5   databaseCredentialsUsedByWebserver(W, D).
6
7 sensitiveDataExfiltrated(D) :- readDatabaseCredentials(A, D).

```

Listing 1: Datalogic rules for the proposed example.

```

1 webserverReachable(Attacker, Webserver).
2 databaseCredentialsUsedByWebserver(Webserver, Database).
3 webserverVulnerableToRCE(Webserver, CVE-2021-41773).
4 webserverVulnerableToRCE(Webserver, CVE-2021-44228).

```

Listing 2: Datalogic facts for the proposed example.

This logic-based network security analyzer allows writing and analyzing attack graphs through Datalog. In logic attack graphs, there are two types of nodes, i.e., *fact nodes* and *derivation nodes*. *Fact nodes* represent conditions that enable an attacker to perform an exploit and reach a goal. They can be *primitive* (i.e., facts that do not depend on derivation nodes) or *derived* (i.e., facts that are not primitive). Derivation nodes represent the exploits that allow an attacker to obtain post-conditions. Each derivation node has an “interaction rule” describing its dependencies. In particular, a derivation node depends on one or more fact nodes that satisfy the rule’s preconditions. Although several MulVAL extensions have been developed, the fundamental concepts are still practical and adopted.

2.1.2. Attack template

When modeling attack graphs, a decisive choice regards the definition of an *attack template*, i.e., the rule set that contains the list of

security conditions and their relationships. The default MulVAL attack templates are mainly based on exploits against known vulnerabilities obtained from scanning and vulnerability assessment tools. Several works aim to extend the base MulVAL attack templates. A comprehensive taxonomy for attack graph generation and usage in network security is provided by Kaynar (2016).

2.1.3. Bayesian attack graphs

In the previous section, we observed that security conditions could be modeled as facts that can be either true or false. However, this is a strong assumption. Researchers have hence explored novel approaches to introduce stochastic variables in attack graphs.

Combining the Bayesian network probabilistic method with attack graphs makes it possible to obtain a *Bayesian attack graph* (Frigault and Wang, 2008). For each exploit node, it is possible to model a *conditional probability table* (CPT) based on AND and OR relationships. In particular, in order to compute CPTs efficiently, loopy propagation algorithms can be adopted. For attack graphs, the Noisy OR/AND (Pearl, 1988) approach is commonly used. If pa_i is the set of probabilities related to the preconditions that must be satisfied to make a node X_i true, it is possible to define noisy-AND and noisy-OR relationships as follows (Munoz-Gonzalez et al., 2019):

$$Noisy-AND : p(X_i | pa_i) = \begin{cases} 0, & \exists X_j \in pa_i | X_j = F \\ \prod_{j: X_j \in pa_i} p_{v_j}, & otherwise. \end{cases} \quad (1)$$

$$Noisy-OR : p(X_i | pa_i) = \begin{cases} 0, & \forall X_j \in pa_i | X_j = F \\ 1 - \prod_{j: X_j \in pa_i} (1 - p_{v_j}), & otherwise \end{cases} \quad (2)$$

Each AND gate in Fig. 4 can be converted into noisy-AND equations, while the noisy-OR equation models the probability of each OR gate. Using these equations makes it possible to obtain a *Bayesian Attack Graph* (BAG).

2.2. Threat graph - revisiting the attack graph definition

In this section, we introduce new definitions that will support the description of the model proposed in Section 4. A threat to a system is either a malicious or unintentional action that harms the system. Threats can be categorized by classifying worldwide security incidents. We divide them in two sets:

- *Goal Threats*, i.e., threats that cause a final impact. In Section 5, we consider two primary goal threats, namely, data exfiltration and ransomware.
- *Vector Threats*, i.e., threats that can be sequentially exploited to enable preconditions for a goal threat.

We also introduce **Initial Threat Preconditions**, i.e., conditions that enable the initial vector threat of the sequence that led to a goal threat.

According to the definitions in Section 2.1, it is possible to describe vector threats, goal threats and initial threat preconditions in terms of condition nodes and hence formulate the following threat graph definition:

Definition 5 (Threat graph). A threat graph TG is an attack graph G where:

- intermediate nodes represent **vector threats**, i.e., a single step in the sequence of threats (i.e., the “threat path”) exploited by a threat actor in order to reach a goal threat;
- goal nodes represent **goal threats**, i.e., the final steps of a threat path followed by a threat actor;
- initial nodes represent the **initial threat preconditions**.

In the previous definition, we explicitly refer to “threat actor” to underline the difference from a skilled attacker. In particular, a threat

actor is a malicious person or organization that does not necessarily have any technical skills.

From the threat graph, it is possible to derive the **Bayesian Threat Graph** (BTG) in the same way as the Bayesian attack graph (see Section 2.1.3).

BTG, which stands for Bayesian Threat Graph, is a Bayesian model derived from the related threat graph. BTG is formally equivalent to the Bayesian Attack Graph, meaning that the formulae described in Section 2.1.3 can be applied in the same way.

There is indeed a subtle yet significant semantic difference between an Attack Graph and a Threat Graph, which basically reflects the difference between a threat and an attack. A threat can be either intentional or unintentional, whereas an attack is intentional by definition. As such, a threat is a circumstance that has potential to cause loss or damage, while an attack is an explicit attempt at causing damage. The introduction of Threat Graphs allows us to explicitly catch the above semantic difference, by incorporating additional security risks, such as those resulting from human errors or negligence. This generalization is especially important when including insiders in the graph model.

Furthermore, we aim to develop a graph model that explicitly incorporates the previously mentioned concepts of goal threat, vector threat, and initial threat preconditions. By extending the attack graph, we can apply these concepts, represent insiders, and create the model as presented in Section 4.

In the proposed model, the number of goal threats is given by the number of analyzed assets. Namely, if N_{Asset} is the number of assets in the system and N_{Goal} is the number of goal threat types, the number of goal threats is given by the following Equation:

$$N_{GT} = N_{Asset} \times N_{Goal} \quad (3)$$

Vector threats can also be categorized according to the required technical level:

- *Non technical threats*: they do not need technical skills. They basically occur when a system publicly exposes sensitive data.
- *Technical threats*: they require IT skills but *no hacking* skills. For example, an anonymous ftp login exposes sensitive data.
- *Advanced threats*: they refer to threats that require hacking skills, such as vulnerability exploitation capabilities.

This categorization needs to be highlighted as it helps define the threat graph edges between pairs of nodes. In fact, non-technical threats may be performed by a variety of threat actors, whereas other threats cannot be performed by employees (even disgruntled ones) having neither technical nor hacking skills. An important consideration is related to the probability and impact of a threat. We define the concept of “measurable threat”:

Definition 6 (Measurable threat). A measurable threat is a threat to which it is possible to assign a financial loss and a cyber incident frequency.

2.2.1. Security controls

In our model, security controls reduce the probability that a threat occurs. We introduce the concept of “addressed threats”.

Definition 7 (Security control). A security control is a tuple $SC = (Cost, AddressedThreats)$, where $Cost$ represents the implementation cost of SC and $AddressedThreats$ is a list of addressed vector threats. After applying security controls, the probability of vector threats is reduced. Consequently, goal threats probabilities are also reduced.

In our model, security controls reduce the probability of addressed threats. In particular, some security controls harden the system by reducing the probability of exploiting a vulnerability. In contrast, others

aim to increase the effectiveness of intrusion detection systems that should induce attackers to be discouraged by the possibility of being discovered. Indeed, this is a strong assumption that requires further work, as the “deterrence level” depends on various factors, such as the attacker’s motivation (Chan and Yao, 2005). We are nonetheless herein assuming that such an assumption holds true.

We can define the security control “coverage” in the following way:

Definition 8 (Security control coverage). Let $\mathbb{T}$ a set of measurable threats used to evaluate risk, and SC a security control. $\mathbb{AT} \subseteq \mathbb{T}$ is the set of threats addressed by the security control. The probability of a threat $at_i \in \mathbb{AT}$ is reduced by r_i when the security control is applied. The security control coverage reduction is defined by the tuple:

$$SecurityControlCoverage = [r_0, \dots, r_n] \quad (4)$$

where n is the number of addressed threats.

Finding how much a security control reduces the probability of addressed threats is challenging. The probability can be estimated through either qualitative or quantitative approaches. Quantitative approaches are preferred, as these estimations allow objective results to be less susceptible to cognitive biases. In order to assess the security control impact against the addressed threats it is crucial to adopt Specific, Measurable, Achievable, Relevant and Time-bound criteria, i.e., we have to define SMART metrics (Doran, 2008).

After security controls are applied, a new Bayesian Threat Graph is generated, and, depending on the addressed threats, the probability of goal threats is reduced accordingly.

We can define a risk strategy as a combination of security controls.

Definition 9 (Risk strategy). Let SC the set of possible security controls and N_{sc} the number of security controls. Each security control can be either applied or not. A risk strategy is the implementation of a subset of security controls. The number of risk strategies is given by Equation (5)

$$N_{RiskStrategies} = 2^{N_{sc}} \quad (5)$$

Each security control has a cost. The implementation cost of a risk strategy depends on the implemented security controls:

Definition 10 (Risk strategy cost). Let SC the set of security controls that a company is going to implement in the system. The risk strategy cost is given by:

$$Risk.StrategyCost = \sum_{i=0}^n c_i \quad (6)$$

where n is the number of implemented security controls, and c_i is the cost of security control $sc_i \in SC$.

2.2.2. Threat impact

The impact of a threat can be computed in the same way as done in the work from Erola et al. (2022). In particular, it can be obtained by considering the financial losses caused by a threat at a specific instant in time.

Definition 11 (Threat impact). Let t be a goal threat of a Bayesian Threat Graph and $FinancialLoss_t$ the financial loss associated with the threat obtained by analyzing the related cyber incidents. We can define the threat impact variable as follows:

$$ThreatImpact = FinancialLoss_t \quad (7)$$

Equation (7) can be computed by considering the current statistics of cyber incident costs for a specific threat. This is not easy, as sev-

eral factors cause cyber losses. Palsson et al. (2020) apply a random forest algorithm to create a relationship between cyber incident factors and several financial cost classes, summarizing a relationship between threat types and financial losses. We leverage this relationship to estimate the global costs in our use case. Anyway, the estimation should also consider the number of breached records. Jacob (2014) observed that there is a logarithmic relationship between the security incident losses and breached records. A recent study by the Cyentia Institute (Cyentia, 2020) confirms this relationship. The study relates the number of compromised records to the financial losses of cyber incidents that occurred in 2020. These considerations can be used to include local impact factors that depend on the company information within the model. By applying a regression model to the Cyentia studies, it is possible to obtain the following formula:

$$ThreatImpact_{asset} = e^{10.36+0.55 \cdot \ln(records_{asset})} \quad (8)$$

Equation (8) relates the number of records stored in an asset to the financial losses for a company caused by cyber incidents involving the asset. In our model, each asset can be affected by one or more threat goals. Each asset contains $records_{asset}$ sensitive data, and we assume that a threat completely breaches it. Through this assumption, we can give an impact score for each asset in the model.

3. Related works

Several works inspired our framework. Khosravi and Bafghi (2020) present a network security risk management framework based on Bayesian Decision Networks that allows the selection of the best security controls’ combination under budget constraints. The model is focused on software vulnerabilities exploitable by attackers having hacking skills. In our work, we will extend it to cover more generic threats and, in particular, insider threats. Our model also includes additional security controls to deal with insider threats and proposes a different interpretation of several concepts like, for example, the way the security controls address threats. Namely, in our model, unlike BRMF, security controls reduce threat probabilities rather than decreasing their impact (see Section 2.2.1). We will give more details in the next section. Erola et al. (2022) allowed us to gain relevant insights into several aspects. For example, considering the CIS (Center for Internet Security) critical security controls and the security impact in terms of data loss. Although we utilized the logarithmic relationship between security incident losses and breached records, the approach proposed by Erola et al. might indeed be integrated to also assess impact loss.

Psychological, social, and biological information (Levy, 2010) works led us to integrate employee satisfaction processes, technical training, and stress monitoring as security controls in our final framework including insider threats (Saito et al., 2021; Roll et al., 2019; Wong et al., 2019).

The current insider threat research is mainly focused on discovering malicious behaviors in systems (Al-Mhiqani et al., 2020). Many works evaluate the detection performance by leveraging the insider threat dataset provided by the Computer Emergency Response Team (CERT) division (Lindauer, 2020). The dataset has both monitoring and behavioral features. In particular, OCEAN personality traits (Rothmann and Coetzer, 2003) are used to characterize the employees. Tuor et al. (2017) develop an unsupervised deep learning model to detect insider threats, while Yuan et al. (2018) design an alternative deep neural network and show that it increases the performance detection metrics compared to other approaches. Finally, Zhang et al. (2021) demonstrate that ensemble learning and self-supervised techniques increase the detection of malicious activities.

Several works aim to propose insider threat models by adopting formal methods (Wing, 1990). An outstanding contribution is represented by the “CERT Guide to Insider Threats” (Cappelli et al., 2012). Other two relevant formal languages (Magklaras et al., 2006; Kammuller and Probst, 2017) are mentioned in a systematic survey about insider threats

from Xiong and Lagerström (2019). To the best of our knowledge, no unifying theory currently exists to model insider threats. As to threat categorization, we could not find in the literature a well-founded set of insider threats. Though, we were able to get relevant information from statistical sources. In particular, the Vocabulary for Event Recording and Incident Sharing (VERIS) (The veris framework, 2022) offers a set of metrics designed to provide a common language for describing security incidents in a structured and repeatable manner. Through this database, it was possible to define the most relevant threats, by also including the insider ones. Another relevant data breach source from which to infer further insider threat scenarios was provided by Verizon's Data Breach Investigation Report (DBIR) (Verizon, 2021). Through data analysis, we were actually able to extract various threats (see Table 6). Nurse et al. (2014) propose an interesting framework to characterize insider attacks and pose countermeasures. In his disruptive paper (Greitzer, 2019), Greitzer shows that emerging government guidelines specify only minimum standards for insider threat monitoring, analysis, and mitigation programs, so authors offer insights to fill the gap.

Our work widens the research scope to include insider threats in risk management processes. In fact, even if risk management frameworks are extensively adopted to prevent security risks in companies, their application to address insider threats is relatively unexplored. Logan and Clarkson (2020) show that the insider is a significant risk for companies and try to make available a qualitative approach to define insider-based risk assessment. Anyway, it is an early work that does not provide many details about how to integrate insider threats into risk management processes. Stone (2021) offers systematic reviews that confirm the benefits of using the risk-management process to combat insider threats. In our model, we define a threat graph that is conceptually based on attack graphs. Attack graph models are extensively adopted to model the behavior of attackers in order to prevent attacks from being successful. Lallie et al. (2020) provide a comprehensive overview that offers a theoretical foundation of attack graphs and shows there is no standard method for representing them. We think that the main cause behind such a lack of standardization is the quest for flexibility of such models. Still, it is also their strength, as it is possible to define different attack "view" levels and, most importantly, to have a clear vision of the attacker's behavior. In fact, attack graphs show the sequential steps of an attacker who breaks into a system and relate the potential threats to the affected assets. It is an essential feature in risk management, as the impact level depends on the asset's importance. To underline the benefits of the visual attack graph representation, Lallie et al. (2018) confirm that such models can increase the cyber-attack perception. In this work, in order to improve the understanding of the model, we represent high-level threats through attack graphs. By using such an approach, it would also be possible to model low-level threats. Current works based on attack graphs are focused on the application to cyber-physical systems and Internet of Things (Ghazo et al., 2020).

3.1. Insider threat analysis

Several works propose approaches to detect insider threats and select the most effective defensive strategies to minimize risks. Mathew et al. (2008) define a theoretical model called Capabilities Attack Graphs (CAG) to detect the most probable attack paths on the basis of the cost related to the security controls and vulnerability score. Our threat graph is similar to their work, as it is basically asset-centric. However, the authors do not include asset values in their cost estimation. Furthermore, their model is based on CERT vulnerabilities and seems to rely only on what we have herein defined as *hacking threats*.

Bishop et al. (2010) propose a descriptive research work that gives interesting insights into the integration of insider threats in risk management, such as the importance of access resources and psychological indicators. However, their model includes neither external attackers nor asset values when evaluating security risks. Therefore, no quantitative metrics are defined to evaluate security risk strategies.

Roy Sarkar (2010) does not propose a model, yet provides a comprehensive set of technical, behavioral, and organizational measures to predict the likelihood of insider threats. Axelrad et al. (2013) propose an interesting approach that encloses several insider features, such as dynamic environmental stressors and static personality, into Bayesian networks. Although the approach focuses on detection rather than security risk assessment, it provides a point of reflection about the usefulness of Bayesian networks to model insider threat behavior. However, the authors do not consider relationships between insiders and assets.

Other works model the insider threat through game theoretic models such as that proposed by Joshi et al. (2021). In their work, adversarial risk analysis (ARA) addresses the insider threat problem. It is an interesting work as it proposes an attack-defense approach to select the best defensive action that effectively counters insider threats. Furthermore, since it models both the attacker's and the defender's behavior, it offers a richer expressiveness than our model. However, it does not consider the importance of assets in the utility function that defines the attacker's behavior. Also, it does not provide detailed information about estimating security control costs.

In our opinion, one of the most relevant works about including insider threats in risk management is provided by Greitzer et al. (2021). The work proposes a knowledge elicitation model to support the development of insider threat risk models. Although the proposed model neither focuses on defining a risk strategy, nor illustrates the approaches for estimating costs, it is a fundamental piece of work that can be leveraged to define insider threat preconditions. Table 1 summarizes the mentioned works and their properties.

Indeed, each of these models offers relevant insights that can be of inspiration to enrich our work. We will provide some pointers in the concluding section of the paper.

3.2. Attack graphs and risk analysis

Attack graphs effectively underline the relationship between attacks and nodes in a network system, but it is challenging to define which security measures should be applied to address such attacks. On the other hand, well-founded risk assessment methodologies allow for defining risk strategy effectively but are usually adopted without considering the real system environment. Hence they cannot be leveraged by network administrators to mitigate security risks. A pioneering Bayesian attack graph framework was proposed by Poolsappasit et al. (2012) to formalize a dynamic network risk assessment model. Several works propose Bayesian approaches to assess network security risks. However, they mainly focus on network security technical threats and estimate threat probabilities using vulnerability scoring systems designed to capture technical characteristics of software, hardware, and firmware vulnerabilities, such as the Common Vulnerability Scoring System (CVSS). Table 2 compares our work with similar approaches. As it is possible to observe, current Bayesian risk management models mainly aim to mitigate technical threats. Insider threats and non-technical threats are typically not taken into account.

3.3. Base risk management framework (BRMF)

A work that explicitly implements Bayesian attack graphs to perform risk assessment is authored by Khosravi and Bafghi (2020). The paper in question can help identify the limitations of existing approaches.

For simplicity, we will call the authors' work Base Risk Management Framework (BRMF). BRMF leverages the visual representation of attack graphs, and therefore allows to share attack scenarios with non-technical teams easily. Its strength resides in the fact that it is self-explanatory. As the attack graph model is widely adopted, BRMF can be applied in many contexts. The attack graph model perfectly fits an attacker who tries to exploit remote vulnerabilities in order to break inside a system, compromise internal servers through lateral movement, and eventually exfiltrate sensitive data from the corrupted targets.

Table 1

Comparison between related insider threat analysis works. Legend: Eternal Attackers: if the model includes external attackers; Technical Threats: if the model includes technical threats; Non-technical threats: if the model includes non-technical threats; Asset value: if the model includes asset values; SMART metrics: if the model defines SMART metrics; Security controls: if the model defines security control costs; Insiders and assets relationships: if the model analyzes relationships among insiders and assets.

	Mathew et al. (2008)	Bishop et al. (2010)	Axelrad et al. (2013)	Joshi et al. (2021)	Greitzer et al. (2021)	Our work
External Attackers	Y	N	N	N	Y	Y
Technical threats	Y	N	N	Y	Y	Y
Non-technical threats	Y	Y	Y	Y	Y	Y
Asset value	N	N	N	N	N	Y
SMART metrics	N	N	N	N	N	Y
Security controls	N	Y	N	Y	N	Y
Insiders and assets relationships	Y	Y	N	Y	N	Y

Table 2

Comparison between related risk analysis works based on attack graphs. Legend: Probability metric: Used Probability Metric; Asset impact: if asset impact is included in the risk analysis; Non-technical threats: if the attack template includes non-technical threats; Insider threats: if the attack template includes insider threats.

Work	Attack graph template	Probability metric	Asset impact	Non-technical threats	Insider threats
Munoz-Gonzalez et al. (2019)	Technical attacks, based on CVE. Do not include 0-days or global security incidents	CVSS score	N	N	N
Behbehani et al. (2022)	Web attacks. Manually creates CVSS scores to evaluate probabilities	CVSS score	N	N	N
Sawilla and Ou (2008)	Network attacks, extracts metrics and vulnerabilities from public known databases such as NVD	CVSS score	N	N	N
Khosravi and Bafghi (2020)	Based on technical attacks, but introduces interesting approaches to define a risk management strategy based on Bayesian attack graphs	CVSS Score	Y	N	N
Deng et al. (2023)	Based on technical attacks, but introduces a new metric to evaluate asset importance	SIR model (Ross, 1916)	Y	N	N
Our work	Based on "threats", composed of technical, non-technical and insider threats. Use global security incidents to estimate threat probabilities	Global security incident trends	Y	Y	Y

The model allows to link attack scenarios to the network topology, by enabling security teams to easily and rapidly understand what should be protected and hardened. The model can become too complex if large network scenarios are considered, which might negatively impact its visual representation power. For this reason, it is crucial to choose a proper abstraction level for the attacks adopted in the model, as we did in our work.

3.3.1. BRMF limitations

As the attack graph approach is very flexible, we chose to start from the BRMF model (which only focuses on the exploitation of vulnerabilities) and enrich it in order to cover other threats while also widening the scope of several related concepts. In fact, despite its advantages, BRMF has a few intrinsic limitations, like, for example, the fact that it is only focused on vulnerabilities. Several works adopted an attacker risk assessment procedure making use of the base metrics (i.e., *Confidentiality Impact*, *Integrity Impact* and *Availability Impact*) by using existing vulnerability databases (e.g., the one proposed by the National Vulnerability Database – NVD, 2022). Unfortunately, this approach is weak for several reasons. In fact, the probability of an attack that exploits vulnerabilities on a target does not just depend on the severity of such vulnerabilities but also on additional factors. For example, critical vulnerabilities might affect a target representing a rarely used asset inside the company. For this reason, even if severity is critical in such a case, potential attackers will likely not exploit such a flaw, as they will focus on investigating the most relevant widely deployed vulnerabilities they have discovered. Hence, a parameter such as the cybersecurity incidents trend is in this case a better probability indicator, as it reflects the most widely deployed cyber attacks against companies. Also, when

using attack models based on known software vulnerabilities, it is not possible to model other types of threats, such as:

- *0-day attacks*: if CVSS scores are used to evaluate risks, it is not possible to model attacks that exploit unknown vulnerabilities;
- *Weak or default credentials issues*: attackers might compromise a target server by using default credentials. This is related to negligent system administrators who erroneously do not harden passwords;
- *Social engineering attacks*: the attacker might, e.g., send a phishing e-mail to break into the system.

This limitation is much more impactful when considering non-technical insider threats. In fact, even if an insider threat might exploit vulnerabilities, this is a rare condition. Munshi et al. (2012) underline the discrepancy between the academic literature and empirical data in focusing on insider's technical skills. Although several models demonstrated that technical skills might increase the probability of an insider threat, empirical data show that non-technical threats are the primary cause of incidents.¹ Malicious insiders usually leverage privileged access to hosts, computers, and systems. A relevant consideration is that they can also exploit the physical access to the systems, so it is essential to model physical assets.

Since BRMF only considers vulnerabilities, the proposed security controls fall in the category of network security solutions, such as applying patches, disabling services and/or adding a network Intrusion

¹ According to Verizon's DBIR, 74% of breaches in 2023 involved the human element (<https://www.verizon.com/business/resources/reports/dbir/>, accessed: 17-06-2023).

Detection System (IDS). Through network-related security controls, it is not possible to include further threats. For this reason, we consider the CIS (Center for Internet Security) Critical Security Controls (SANS, 2008, 2021) provided by the SANS institute² in the same way as proposed in Erola et al. (2022). As stated by the authors, SANS has a lack of non-technical controls. They introduce organizational culture, information-security programs, etc., but do not consider human factors. An employee might be influenced by several factors, such as disgruntlement or overworking. Even if several studies, e.g., Kweon et al. (2019), have been carried out to explore the importance of security awareness courses to reduce the risk of social engineering attacks, none of them, to the best of our knowledge, integrates employee satisfaction programs in the risk management process. Many works confirm the relationship between job satisfaction and performance. A crucial research study by Vincent et al. (1960) explores the intrinsic and extrinsic factors that influence job motivation. Job dissatisfaction and overworking can increase human error and lead to malicious behaviors, thus introducing security risks. For this reason, it is important to conduct surveys that estimate the employees' job satisfaction level as well as their burnout level (Kappala, 2015). In Section 4.7 we show how it is possible to extend CIS Critical Security Controls in order to include insider threats.

One more weakness of BRMF derives from the approach used to relate security controls to security risks. Namely, in BRMF, security controls reduce the damaging impact. Still, it is unclear how is it possible to estimate how much a security control reduces the impact of an attack. The accurate evaluation of the risk reduction by applying security controls is an open research question. Still, it is important to underline that security controls reduce threat probability rather than threat impact. Based on these considerations, we can simplify the approach by inferring the reduced threat probabilities of a Bayesian Graph when a subset of the available security controls is applied. In our approach, we compute the risk by multiplying the threat probability by the threat impact. To summarize, we design a model that:

- extends the attack concept by including other threat scenarios, e.g., weak credentials, sensitive data exposure, social engineering attacks, etc.;
- defines an alternative approach to evaluate the best security controls combination through the risk analysis obtained by generating Bayesian graphs having reduced Conditional Probability Tables (CPTs);
- evaluates threat probabilities based on cyber incident trends, as well as threat impact based asset values;
- includes insider threats in the model by adding specific security controls capable of addressing them.

4. Towards an enriched risk management framework for insider threats

In this section, we propose a risk management framework that generalizes both threat and security metrics used in the BRMF attack graph by also including insider threats.

4.1. Beyond BRMF limits

A relevant recent work (Erola et al., 2022) inspired us to devise a generalized BRMF model. In their study, Erola et al. (2022) design a system to evaluate Cyber Value-at-Risk in networked architectures. The approach is interesting under several perspectives:

- threats are not related to skilled attackers that exploit software vulnerabilities, but are rather defined through known datasets such as Advisen (2019);
- real incidents are used to model threat probabilities and evaluate their impact;
- assets are not just servers but also include people, software, abstract concepts, etc.

We use a similar approach to extend the risk framework by including other types of threats, as well as by redefining the risk strategy in terms of risk and security controls implementation cost.

4.2. Risk and security risk strategy

For each goal threat, we can define an asset risk given by the product between threat probability and threat impact. The total risk is given by Equation (9):

$$Risk = \sum_{i=0}^{N_{goal}} \sum_{j=0}^{N_{asset}} P(T_i) \times I(A_j) \quad (9)$$

Each asset (A_j) can be affected by N_{goal} goal threats, and each goal threat T_i has a $P(T_i)$ probability, obtained after the inference of the Bayesian Threat Graph generated by the implementation of Algorithm 1.

4.3. An algorithm to estimate the best risk strategy

The aforementioned definitions allow us to define an algorithm to evaluate the best security controls selection under budget constraints (Algorithm 1).

Algorithm 1 Bayesian reduced threat algorithm.

Require: *ThreatGraph*: the threat graph.
Require: $N_{RiskStrategies}$: the number of risk strategies

```

1: ThreatRisks ← EmptySet()
2: for  $i < N_{RiskStrategies}$  do
3:   subset ← GetSubsetSecurityControls( $i$ )
4:   RiskStrategyCost ← GetImplementationCost(subset)
5:   btg ← GenerateBayesianThreatGraph(subset, ThreatGraph)
6:   MakeInference(btg)
7:   GoalNodes = GetGoalNodes(btg)
8:   for all  $g \in GoalNodes$  do
9:     asset ← GetAssetFromGoal( $g$ )
10:    loss ← asset.GetSecurityLoss()
11:    prob ← GetProb( $g$ )
12:    ThreatRisks.append(Risk(loss, prob))
13:   end for
14:   Risk ← Sum(ThreatRisks)
15:   StoreCombination( $i$ , TotalRisk)
16:    $i \leftarrow i + 1$ 
17: end for
```

The defined algorithm allows selecting the risk strategy that maximizes risk reduction. As explained in Section 2.2.1, it is possible to select the strategy depending on either risk reduction or budget constraints. For each risk strategy, a Bayesian Threat Graph is generated (Line 6). The implemented security controls reduce the threat probabilities vector, thus also reducing risk. For each goal threat, the risk associated with the related assets is estimated by using Equation (8) (Line 11).

In the previous section, we have observed that a threat has several preconditions that influence its probability. In the same way as BRMF, we do not formalize the relationship between the preconditions and the probability. The analysis of these relationships would be too complex and depends on the specific threat as well as the context in which the model is applied. As in almost all of the cited related works, we assume that the implementation of a security control is a boolean condition that can either protect a system or not. Another important assumption

² Officially the Escal Institute of Advanced Technologies. SANS stands for SysAdmin, Audit, Network, and Security.

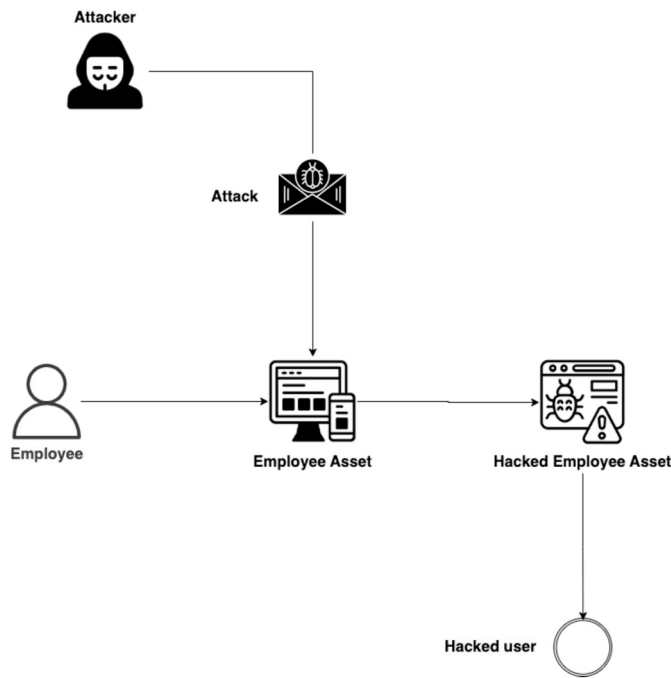


Fig. 5. Hacked insider.

is that security controls are immune from vulnerabilities, while they might potentially introduce further threats into the system. For example, the IT administrator might set default credentials, and/or a monitoring system might itself present vulnerabilities. In our model, insiders can be often represented as non-technical attackers with system privileges higher than external attackers. For the sake of completeness, we remark that an even worse situation is the one in which the insider also has technical skills. In such a case, the insiderness (i.e., the fact that higher privileges do exist) property translates into the most impactful consequences on the security of an organization.

Namely, we model an insider threat as an attacker that satisfies the “insiderness” property.

Insider Threat Consideration 1 (Insiderness property). The insiderness property is a threat precondition that enables an attacker to access the system with higher privileges than external actors.

As an insider threat is a company employee, they introduce non-technical threats into the system. They might exfiltrate data without exploiting vulnerabilities, while also bypassing monitoring systems and hence reducing the effectiveness of the implemented security controls.

4.4. Hacked insiders

Hacked insiders are easily represented in our model by introducing the “hacked” threat precondition. An attacker that hacks an employee changes the BTG state, enabling new threats inside the system.

Insider Threat Consideration 2 (Hacked user). A hacked user is an initial threat precondition for an attacker that has been able to hack an employee of the target organization by defeating the security controls applied to the employee’s system.

Fig. 5 shows an example of an external attacker that compromises an internal user, thus enabling a “hacked user” initial threat precondition. Such a precondition allows the attacker to obtain higher privileges in the system, hence enabling privileged threat paths.

4.5. Unintentional insiders

An unintentional insider might expose sensitive data, disable a security control and/or send sensitive data to the wrong recipients. These events introduce threats into the system. Hence, they can be modeled as preconditions that depend on unintentional human errors that cause security flaws.

Insider Threat Consideration 3 (Unintentional insider threats). An employee could make unintentional mistakes that generate security flaws exploitable by an attacker, i.e., initial threat preconditions.

Fig. 6 shows that a human error on tasks affecting security generates an initial threat precondition (i.e., a “security flaw”). Unintentional mistakes can be influenced by several factors. The impact of factors on human errors can be computed using known approaches with some variations. Firstly, “unawareness” should be considered as a potential factor, which could be mitigated thanks to security training courses. Secondly, when considering the impact of human error on security, it is important to account for the number of security tasks over the total tasks assigned to the employee. The human error model gives an indication of the general error that an employee might commit during the execution of an IT task. If N_{SEC} is the number of tasks that affect security and N_{TOT} is the total number of tasks assigned to the employee, the probability that an employee’s human error affects security (i.e., the threat precondition) is given by:

$$P(\text{SecurityFlaw}) = P(\text{HumanError}) \cdot \frac{N_{SEC}}{N_{TOT}} \quad (10)$$

Several authors explored models for human error estimation. Reason (2000) analyzes human error through both a person and a system approach and explores the risks of mishaps in clinical practice. Yazdanparast et al. (2018) propose an optimization-based resource allocation algorithm that includes human error factors. Human error is also investigated through biological models. Holroyd and Coles (2002) investigated the neural basis of human errors, and recent studies have devised prediction models by using biological information. Though, in Section 5 we do not leverage any advanced human error probability model, but rather consider the precondition as a boolean variable. As part of our future work, we will focus on applying such error models in order to evaluate their effectiveness in quantifying security risks introduced by human errors.

4.6. Malicious insiders

Malicious insiders are internal attackers who introduce vector threats that depend on their system privileges. The “malicious intention” is the main precondition for this threat. Such a precondition depends on several factors, like behavioral, personal, social, and psychological ones.

Insider Threat Consideration 4 (Malicious insider). A malicious insider is an attacker that satisfies the insiderness property.

Fig. 7 shows the relationship between the insiderness property, namely, an *insider threat precondition*, and several triggering factors.

The insiderness property can be ascribed to several factors, such as personal problems, disgruntlement, OCEAN personal traits (see Section 3), etc. Unfortunately, no study carefully analyzes this relationship. Current works are ineffective in discovering the triggering factors that influence the behavior of an employee. Martinez-Moyano et al. (2008) proposed an interesting dynamic model that we are going to explore in order to integrate such a relationship into our framework. The insiderness level might be obtained by conducting employee satisfaction surveys (Popovic et al., 2015). It is essential to underline that external attackers also have a personality, might have personal problems, and,

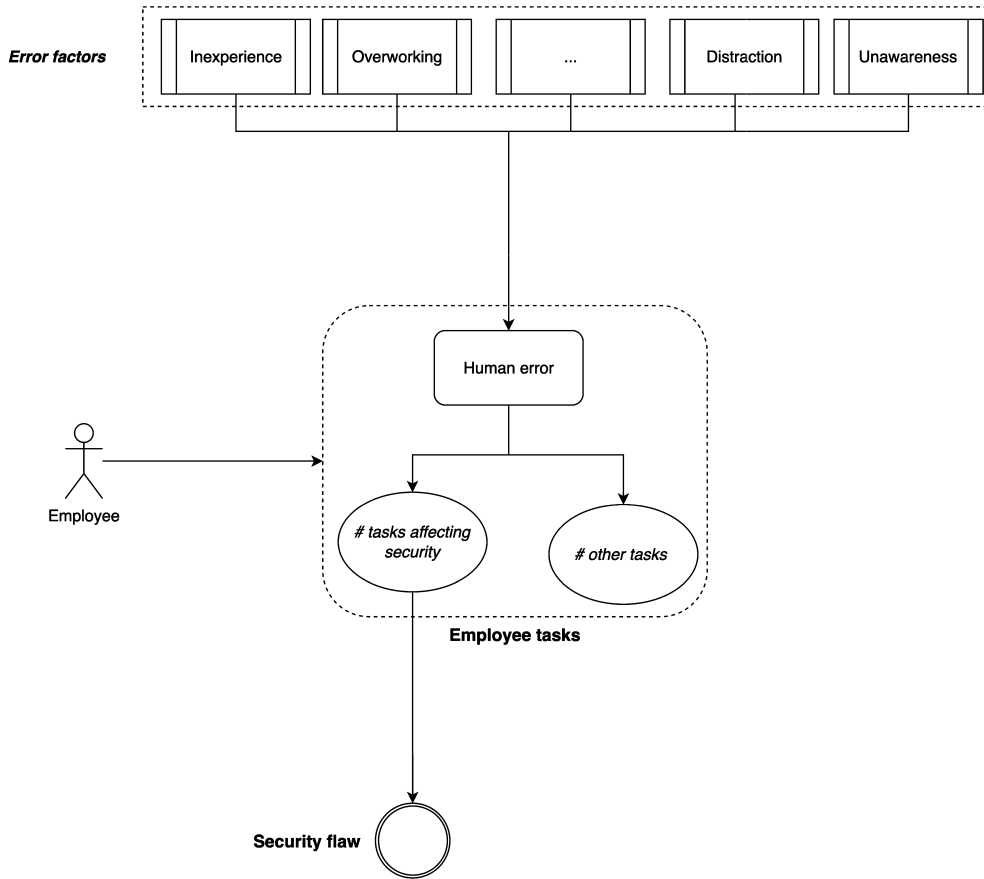


Fig. 6. Human error and initial threat condition.

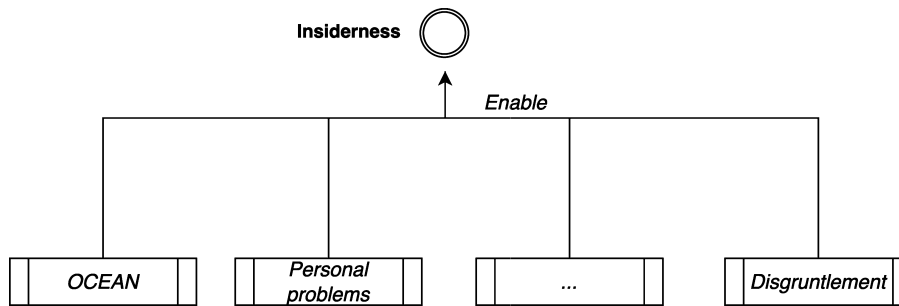


Fig. 7. Insideress triggering factors.

depending on the person's relationship with the organization, might also be disgruntled (e.g., a disgruntled customer). However, we do not include these factors in the model as we assume that external entities, i.e., attackers with partial or no access to the system, already have malicious intentions. We were interested in modeling which factors turn an employee into a malicious employee, as those users have higher privileges in the system. For this reason, we define the "insideress" property and relate it to the previously illustrated triggering factors. Insiders have specific features. For sure, more attack paths are available to them thanks to their facilitated access to the network. It would anyhow be interesting to extend this concept to the wider category of supply-chain attacks (Warren and Hutchinson, 2000). It would anyhow be interesting to extend this concept to the wider category of supply-chain attacks (Reason, 2000). In Section 6 we will explore this topic in more detail.

Fig. 8 summarizes the aforementioned considerations. Insideress, security flaws, and hacked users can be modeled as threat preconditions. In this way, it is possible to integrate insider threats into a unified model, i.e., the threat graph. In the use case scenario proposed in Section 5, we will treat insider threat preconditions as boolean variables. As a future improvement, we will try to refine such an assumption by leveraging the recent work conducted by Greitzer et al. (2021).

4.7. Security controls for insider threats

As anticipated in Section 3.3.1, CIS Critical Security Controls do not include non-technical controls. Therefore, we extend them in order to model security controls for insider threats.

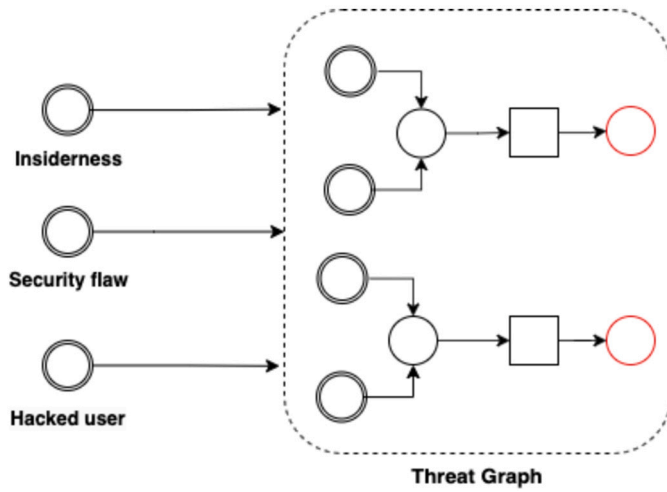


Fig. 8. Insider threats and threat graph.

Table 3
Security controls for the proposed use case.

CIS Security Control	Name
CIS_01	Inventory and Control of Enterprise Assets
CIS_02	Inventory and Control of Software Assets
CIS_03	Data Protection
CIS_04	Secure Configuration of Enterprise Assets and Software
CIS_05	Account Management
CIS_06	Access Control Management
CIS_07	Continuous Vulnerability Management
CIS_08	Audit Log Management
CIS_09	Email and Web Browser Protections
CIS_10	Malware Defenses
CIS_11	Data Recovery
CIS_12	Network Infrastructure Management
CIS_13	Network Monitoring and Defense
CIS_14	Security Awareness and Skill Training
CIS_16	Application Software Security
CIS_17	Incident Response Management
OTH_01	Employee rewards
OTH_02	Employee engagement survey for the reduction of employees' disgruntlement level
OTH_03	Implementation of a process for reducing employees' turnover
OTH_04	Technical training for unskilled IT personnel and software developers

Insider Threat Consideration 5 (*Security controls for insider threats*). The security controls should include organizational processes for addressing employees' disgruntlement and overworking conditions.

In order to address insider threats, we include four additional security controls (OTH_01 through OTH_04) besides those provided by SANS (CIS_01 through CIS_17). Table 3 lists the security controls considered for the proposed use case.

Each CIS_i represents one of the Critical Security Controls provided by SANS, while every OTH_i is a security control that we have included to address insider threats. As already stated in Section 2.2.1, it is crucial to define SMART metrics to evaluate the effectiveness of the implemented security controls. In order to achieve such an evaluation, Viegas and Kuyucu (2022) suggest a list of Key Performance Indicators (KPIs). These KPIs can be used to estimate the security control effectiveness against the addressed threats. It is possible to map each security control onto these metrics and define formulae that combine them to assess the threat probability reduction. Namely, we define the following relevant SMART metrics:

- $N_{i_detected}$: the number of incidents detected by CIS_i ;

Table 4
Reduction percentage per security control for addressed threats.

SC	Name	% Reduction
CIS_03	Data Protection	$\frac{N_{i_detected} - FP_i}{(N_{i_detected} + FN_i + FP_i)}$
CIS_04	Secure Configuration of Enterprise Assets and Software	$\frac{N_{misconfigured_services}}{N_{total_services}}$
CIS_05	Account Management	$\frac{(N_{i_detected} - FP_i)}{(N_{i_detected} + FN_i + FP_i)}$
CIS_06	Access Control Management	$\frac{(N_{i_detected} - FP_i)}{(N_{i_detected} + FN_i + FP_i)}$
CIS_07	Continuous Vulnerability Management	$\frac{N_{vulnerable_services}}{N_{total_services}}$
CIS_09	Email and Web Browser Protections	$\frac{(N_{i_detected} - FP_i)}{(N_{i_detected} + FN_i + FP_i)}$
CIS_10	Malware Defenses	$\frac{(N_{i_detected} - FP_i)}{(N_{i_detected} + FN_i + FP_i)}$
CIS_13	Network Monitoring and Defense	$\frac{(N_{i_detected} - FP_i)}{(N_{i_detected} + FN_i + FP_i)}$
CIS_14	Security Awareness and Skill Training	$\frac{(N_{i_detected} - FP_i)}{(N_{i_detected} + FN_i + FP_i)}$
CIS_16	Application Software Security	$\frac{N_{certified_employees}}{N_{employees}}$
OTH_04	Technical training for unskilled IT personnel and software developers	$\frac{N_{phishing_victims}}{N_{employees}}$

- FP_{i_alerts} : false positives, i.e., the number of alerts erroneously triggered by CIS_i ;
- $FN_{i_incidents}$: false negatives, i.e., the number of security incidents not detected by CIS_i ;
- $TP_{i_incidents}$: true positives, i.e., the number of security incidents detected by CIS_i ;
- $N_{total_services}$: the total number of services in a system;
- $N_{total_applications}$: the total number of applications in a system;
- $N_{vulnerable_services}$: the number of vulnerable services in a system;
- $N_{vulnerable_applications}$: the number of vulnerable applications in a system;
- $N_{misconfigured_services}$: the number of misconfigured services in a system;
- $N_{phishing_victims}$: the number of employees who have fallen victim of a test phishing campaign;
- $N_{employees}$: the total number of employees.

These metrics might be obtained by analyzing historical security incidents and performing security audits on the company. For example, vulnerability assessment activities help determine both $N_{vulnerable_services}$ and $N_{total_services}$, while controlled phishing sessions might be conducted to compute $N_{phishing_victims}$. For each security control, we define a formula that represents the reduction percentage of the addressed threat. Table 4 shows the security controls and reduction formulae for addressed threats. We exclude CIS_01, CIS_02, CIS_15, and CIS_18 from the list since such controls are related to asset inventory and Penetration Testing activities. As it is impossible to evaluate the threats without knowing assets, data, and security flaws, we consider them as “precondition controls” that are mandatory in order to implement a security risk management process. With regard to OTH_01, OTH_02 and OTH_03, they are missing in Table 4 since it is challenging to define a quantitative metric to evaluate their effectiveness. We aim to further explore such a problem in future works. The reduction percentage reported for these indicators in the third column of Table 9 when discussing the proposed use case is a heuristic currently based on our practical experience.

4.8. Enriched Bayesian risk management framework

Fig. 9 shows the enriched model. To summarize, the main differences from the BRMF are the following:

- Host vulnerabilities are replaced by a threat model that embodies both internal and external threats;
- CVSS Base and Environmental Metrics are replaced with goal threat financial losses (i.e., the costs associated with cyber incidents) and

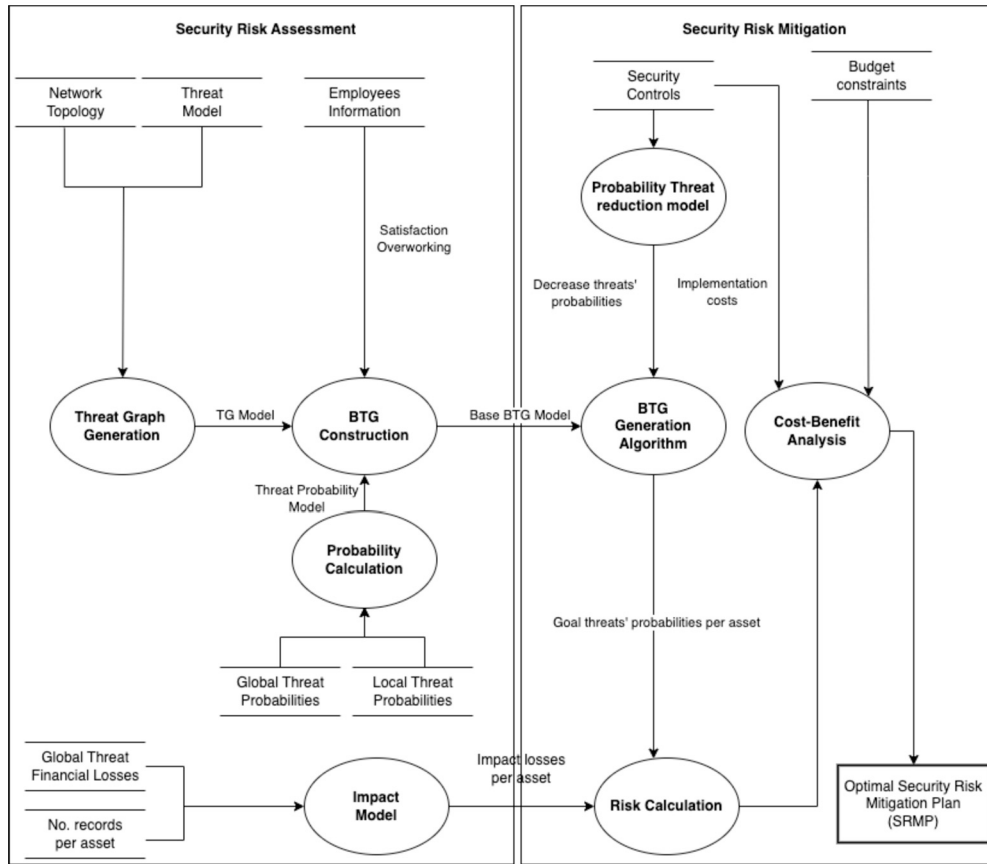


Fig. 9. Enriched Bayesian Risk Management Framework.

data company information, namely the estimated value of the company data;

- Employee information such as employee satisfaction or overworking are considered relevant factors to estimate threat probabilities and generate the BTG;
- The security control selection criteria algorithm is changed, by replacing Bayesian Decision Networks with Bayesian Threat Graphs having cumulative threat probabilities reduced through the implementation of different risk strategies.

5. Use case and performance considerations

In this section, we show a practical example of how it is possible to use the enriched Bayesian Risk Management framework to manage risk inside a company. We describe a process to model threats and calculate the parameters required by our model. Then, we describe an application of the model through a simple use case scenario. Finally, we give an insight into the performance issues of the proposed framework.

5.1. Process to identify threats and parameters

To identify the threats and model parameters, we decided to use the VERIS framework (The veris framework, 2022). The Vocabulary for Event Recording and Incident Sharing (VERIS) collects several metrics that allow to describe cyber incidents in a structured and repeatable manner. The metrics provide useful insights about the occurred cyber-incidents. Some metrics describe the used vectors. For example, the “threat variety” metric provides information about the deployed malware, while the “pattern” field describes the techniques used to perform the attack. Another important metric reports whether the cyber incident was caused by an internal actor or an external one. Hereafter we explain

the process used to find both threats and probabilities. Table 5 summarizes the required parameters to use the model.

5.1.1. Cyber incidents extraction by year

We downloaded the VERIS framework in CSV format (Veris csv database, 2008). The file contains 9135 rows, where each row represents a security incident and is composed of 2550 columns, namely the security incident metrics. We filtered out the incidents notified in 2020, i.e., the entries with the “plus.timeline.notification.year” equal to 2020. With this approach, we ended up with 272 incident entries.

5.1.2. Threat identification and classification

For each security incident, we analyzed the most interesting metrics and created the threat model illustrated in Table 6.

Threats might be caused by either an internal actor or an external one. We identified 19 external threats and 9 internal threats. Internal threats can either be caused by a human error (see, e.g., TID_06), or by intentional action (see, e.g., TID_04). Some threats could be considered both internal and external, such as TID_05, TID_09 and TID_11. Though, we consider them as external only, as all these internal cases are included in the generic internal threat TID_04. We distinguish between TID_11 (web vulnerabilities) and TID_05 (service vulnerabilities) because TID_11 is related to the exploitation of web application vulnerabilities, which is a well-confined domain including specific threats, attacks, and countermeasures (Auricchio et al., 2022). Web server vulnerabilities are indeed included in TID_05. In Section 2.2, we group threats into vector and goal threats. By analyzing the VERIS dataset, we observed two primary goal threats:

- Data exfiltration (TID_17), caused by several vector threats, such as vulnerabilities that disclose data or even administrators that erroneously expose a sensitive data storage.

Table 5

Model parameters for the proposed use case.

Model parameter	Description	Used criteria
Threat model	A set of threats that includes internal actors	Analyze the VERIS framework metrics of the cyber incidents for a particular year to define threats
Global threat probability	The probability that a threat in the model will occur	Divide the number of security incidents caused by the threat by the total number of occurred incidents
Financial Impact	The financial damage induced by the threat	Examine the financial losses caused by the threats in the year
Security Controls	The defensive mechanisms that reduce threat impact	Use CIS critical security controls for external threats. Include further special controls to address insider threats
Security Controls Costs	The costs of implementing the security controls	Estimate the average costs for buying security products and hiring cybersecurity personnel.

Table 6

Identified Threats.

Threat ID	Threat	Actor
TID_01	Sensitive data storage erroneously exposed	Internal (error)
TID_02	Ransomware deployment	External
TID_03	Skimming device installation	External
TID_04	Employee abuses privileged access	Internal
TID_05	Service Vulnerability	External
TID_06	Sensitive information erroneously disclosed by e-mail	Internal (error)
TID_07	Employee account breach	External
TID_08	Spear phishing	External
TID_09	Production data in weak test applications	External
TID_10	Stolen sensitive asset	External
TID_11	Web vulnerability	External
TID_12	Resource saturation through traffic	External
TID_13	Attacker discovers weak passwords	External
TID_14	Legacy environment exploitation	External
TID_15	Credential stuffing	External
TID_16	Fraud-based identity stealing	External
TID_17	Data exfiltration from a company asset	External
TID_18	Hacking Mobile Application	External
TID_19	Password easily guessable by internal users	Internal
TID_20	Sensitive data on USB pen	Internal
TID_21	Data loss or destruction due to IT error	Internal
TID_22	Social engineering attack to spoof identity	External
TID_23	Erroneous disclosure through social media	Internal
TID_24	Business e-mail compromise attack	External
TID_25	External partner breach and access to customer data	Internal
TID_26	Scamming	External
TID_27	E-mail attachment containing a virus	External

Table 7

Threat probabilities for goal threats.

Threat ID	Threat	# of incidents	Prob.
TID_17	Data exfiltration from a company asset	59	0.2169
TID_02	Ransomware deployment	213	0.7830

- Ransomware (TID_02), i.e., cyber-attacks that encrypt systems and exfiltrate sensitive data by blocking the company unless a ransom is paid.

The remaining 25 threats are considered vector threats, i.e., threats that allow triggering goal threats.

5.1.3. Threat probability and impact

To evaluate the threat probabilities, we divide the number of cyber incidents caused by the threat by the total number of cyber incidents. Tables 7 and 8 show the global probabilities for goal and vector threats, respectively.

As stated in Section 2, threat impact is computed based on Equation (8). Each goal threat impacts a single asset. We consider the number of impacted records to estimate the damage induced by the threat.

Table 8

Threat probabilities for vector threats.

Threat ID	Threat	# of incidents	Prob.
TID_01	Sensitive data storage erroneously exposed	67	0.2463
TID_03	Skimming device installation	3	0.0110
TID_04	Employee abuses privileged access	20	0.0735
TID_05	Service Vulnerability	19	0.0698
TID_06	Sensitive information erroneously disclosed by e-mail	7	0.0257
TID_07	Employee account breach	34	0.1250
TID_08	Spear phishing	7	0.0257
TID_09	Production data in weak test applications	1	0.0036
TID_10	Stolen sensitive asset	13	0.0477
TID_11	Web vulnerability	64	0.2352
TID_12	Resource saturation through traffic	1	0.0036
TID_13	Attacker discovers weak passwords	4	0.0147
TID_14	Legacy environment exploitation	2	0.0073
TID_15	Credential stuffing	10	0.0368
TID_16	Fraud-based identity stealing	1	0.0037
TID_18	Hacking Mobile Application	2	0.0073
TID_19	Password easily guessable by internal users	1	0.0037
TID_20	Sensitive data on USB pen	1	0.0037
TID_21	Data loss or destruction due to IT error	2	0.0073
TID_22	Social engineering attack to spoof identity	1	0.0037
TID_23	Erroneous disclosure through social media	5	0.0184
TID_24	Business e-mail compromise attack	2	0.0073
TID_25	External partner breach and access to customer data	3	0.0110
TID_26	Scamming	1	0.0037
TID_27	E-mail attachment containing a virus	1	0.0037

5.1.4. Security controls

As stated in Section 4.7, we consider the SANS Critical Security Controls to address threats. In order to take into account human error, overworking, and disgruntlement factors, we integrate the above mentioned controls with four non-technical additional ones. Some security controls address specific threats, while others cover all of them, thus reducing both the security incident and operational costs required to either restore the infrastructure or increase the intruder detection level. To obtain the reduction percentage for each security control, we assign values to the involved SMART metrics by following the approach defined in Section 2.2.1. Table 9 lists the proposed security controls, the addressed threats, and the threat reduction percentage obtained in this way.

A realistic security cost estimation is challenging. Indeed, we were not able to estimate the threat reduction for CIS_08 and CIS_17. Current studies are focused on finding the security incident costs. Though, they do not clarify how is it possible to evaluate the real Return On Investment (ROI) deriving from the application of security controls that address threats. In this use case, we use average costs retrieved from several enterprise sources to evaluate hardware, software, and security controls' implementation costs (Data, 2021). Such costs should also include employee satisfaction survey processes (Bjarnar, 2021), security training courses (TrustNet, 2022) and security personnel salaries (Cours-

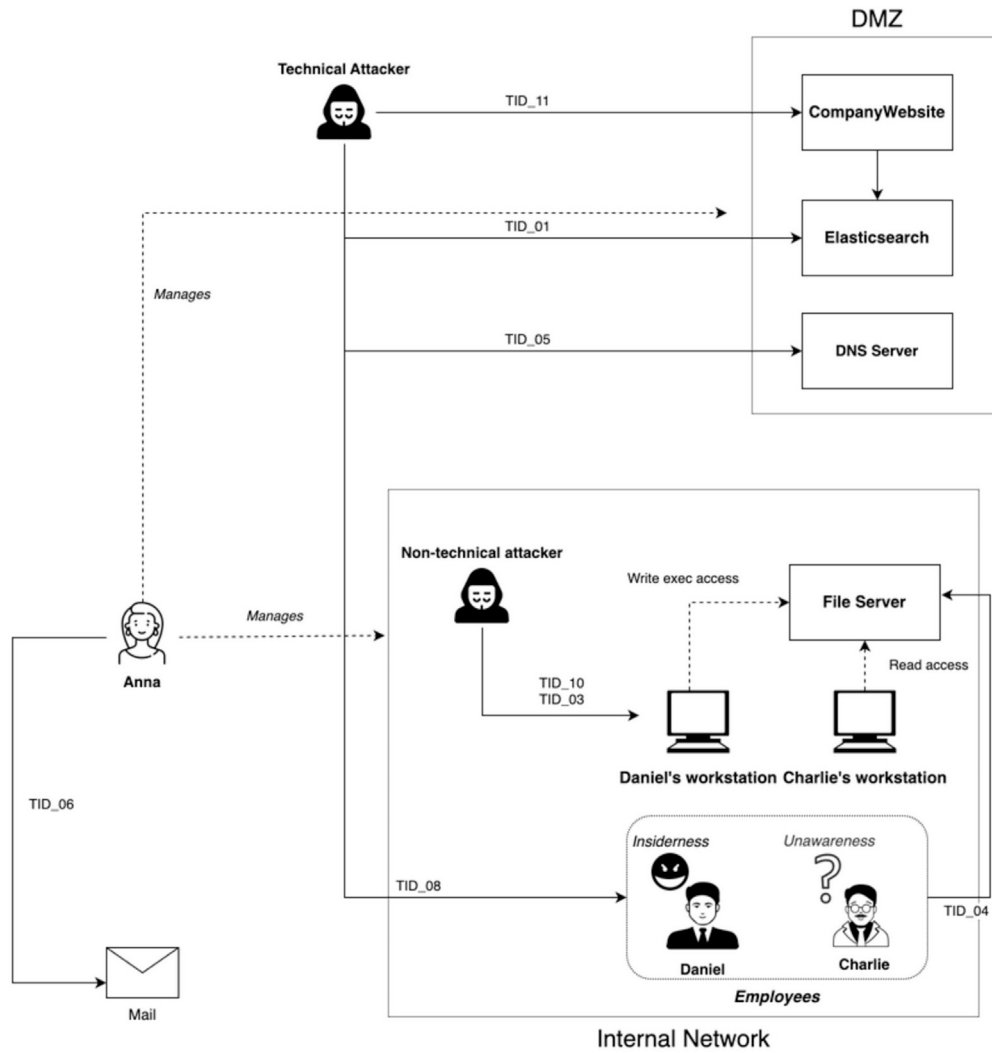


Fig. 10. Use case scenario.

Table 9
Security controls for the proposed use case.

CIS Security Control	Addressed Threats	Reduction
CIS_03	TID_06, TID_09, TID_10	0.9
CIS_04	TID_05	0.6
CIS_05	TID_07	0.7
CIS_06	TID_04	0.75
CIS_07	TID_11, TID_05	0.4
CIS_08	All	N.A.
CIS_09	TID_11	0.9
CIS_10	TID_02	0.72
CIS_11	All	1
CIS_12	TID_11, TID_05	0.95
CIS_13	All	0.95
CIS_14	TID_08, TID_10, TID_15, TID_23, TID_08, TID_11	0.3
CIS_16	TID_11	0.7
CIS_17	All	N.A.
OTH_01	TID_04	0.2
OTH_02	TID_04	0.2
OTH_03	TID_01	0.2
OTH_04	TID_01, TID_11	0.4

era, 2022). This is a strong simplification as these costs are unreliable and depend on several conditions, such as the region, the country, the adopted software, etc. Further studies are required to formalize a formula that allows computing security costs in a proper way. Table 10 lists the estimated costs of implementing security controls.

Table 10
Costs associated with Devices and Processes.

Device / Process	Cost	Periodicity
Firewall	5000	Installation and subscription
Endpoint Detection and Response (EDR)	12	Monthly Cost per device
E-mail protection	4	Monthly Cost per user
Security training costs	2000	Annual cost per 50 employees
Employee satisfaction survey	6000	Annual cost per 50 employees
Technical training for unskilled IT personnel and software developers	2000	Annual cost per 50 employees
Device Management	9	Monthly Cost per device
Identity and Access Management (IAM)	4	Monthly Cost per user
Web Application Firewall (WAF)	4000	Installation and subscription

5.2. Use case scenario

Fig. 10 leverages a use case scenario to show the effectiveness of the enriched BRMF model. It is important to underline that we focus on a simple scenario not taking into account all possible situations and thus showing a few limitations. Though, as we will better discuss hereafter, through the application of specific optimization strategies it is possible to significantly reduce the level of complexity of a real-world use case by properly grouping employees, assets and vulnerabilities into semantically homogeneous clusters. In Section 6 we will point out these limitations and propose approaches for increasing the effectiveness of the model.

The network is composed of a DMZ (“Demilitarized Zone”) and an internal network. The DMZ contains a company website, a data storage (namely, an elasticsearch server), and a DNS server, while a File Server is deployed in the internal network. In this example, we consider three users with different privileges and personal characteristics. Daniel is an “aware” employee, i.e., he is less subject to phishing attacks, but he is also disgruntled for several reasons. Charlie is a satisfied employee, but he is “unaware”, i.e., he has no knowledge about the security risks of using a weak password or opening a suspicious email. We state that Charlie has the “unawareness” property. Anna is the company’s system administrator, and manages the entire infrastructure. She is skilled and aware of phishing problems, but she has to deal with an overload of work, so she is subject to the “human error” property. There are also two attackers. The technical attacker can exploit vulnerabilities, but he/she has only access to the DMZ, while the non-technical attacker has physical access to Daniel’s workstation, so he/she can install a skimming device or steal the computer. In this scenario, we consider a subset of the threats reported in Table 6. The steps needed to implement the process are listed below:

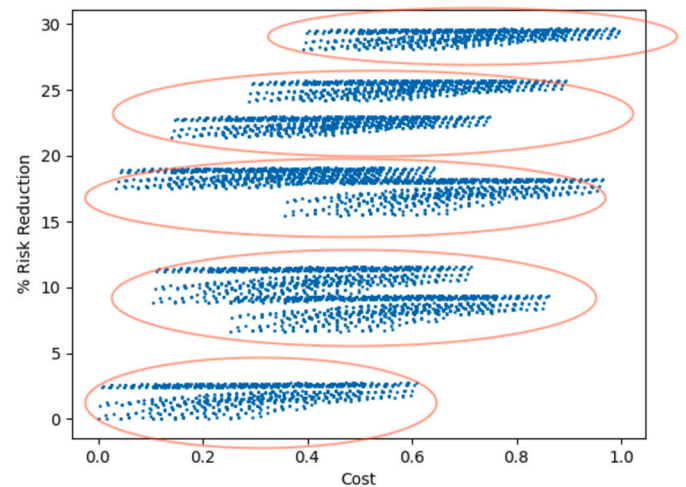
1. generate a threat graph by connecting technical, non-technical, and advanced threats with involved entities on the basis of their skills;
2. apply threat probabilities that will be used to generate the initial Bayesian Threat Graph (i.e., the one in which threats are not mitigated through the application of security controls);
3. apply all the security control combinations and generate the related Bayesian Threat Graphs (i.e., the ones in which threats are mitigated through the application of specific combinations of security controls);
4. obtain the goal threat probabilities and compute both the risk and the risk strategy implementation cost in order to properly select the most suitable risk strategy.

We adapt MulVAL (Ou et al., 2005) to model the rules defined above and generate a threat graph. MulVAL utilizes two files: the former, i.e., “rules.P”, which defines the rules that model threats (namely, rule_interactions), as well as their preconditions, modeled as primitives. The latter, i.e., “input.P”, describes the conditions applied to our scenario. MulVAL focuses on technical vulnerabilities. Though, it contains a Prolog environment that allows defining custom rules. We define rules that include insider threat preconditions, such as “insiderness” and “human errors”. For example, a human error is a precondition for TID_02 (i.e., sensitive information erroneously disclosed by email). The threat graph and security controls illustrated in Table 9 are used as input for Algorithm 1. For clarity purposes, we model high-level threats and do not consider the internal resources, such as file storage paths or NFS server folders. We just focus on host permissions. We assume that ‘exec’ permission includes read and write ones. An important consideration concerns probabilities. Namely, the Bayesian Threat Graph converts primitives into probabilities. With BRMF, authors use the “vulExists” primitive to assign probabilities to the Bayesian Attack Graph. Since we need to link vulnerabilities to threats, we add primitives that model the vector threats. In this way, we can identify vector threats in the Bayesian Threat Graph. We implemented the use case example and pushed the source code to Github (Gx1, NdA994, Ns-unina/insiderthreats, 2022). We used MulVAL to create the threat graph, and the PyAgrum library (Ducamp and Gonzales, 2020) to generate the Bayesian Threat Graph. Several classes and methods have been implemented to model the risk, calculate the CPTs recursively, and implement Algorithm 1. After executing the algorithm, the cost for implementing security controls is computed, together with the residual risk for each implementation of the security strategy. When all the values are computed, the most appropriate risk strategy can be selected based on various criteria. The strategy that maximizes security risk reduction is, of course, the one that implements all security controls. In our case study, the risk reduction deriving from implementing all security controls is 29.65%, and

Table 11

Best first five risk reduction strategies.

#	Implemented security controls	Cost	Risk reduction
195	CIS_10, CIS_12, OTH_03, OTH_04	114,000	29.33
227	CIS_10, CIS_12, CIS_14, OTH_03, OTH_04	115,000	29.48
211	CIS_10, CIS_12, CIS_16, OTH_03, OTH_04	118,000	29.34
4291	CIS_04, CIS_10, CIS_12, OTH_03, OTH_04	118,500	29.33
243	CIS_10, CIS_12, CIS_14, CIS_16, OTH_03, OTH_04	119,000	29.49

**Fig. 11.** Bayesian Risk Management Framework: Cost vs risk reduction analysis.

the related cost is 285,500. Though, it is also possible to establish alternative criteria for reducing risk. For example, based on the maximum risk reduction achieved by implementing all security controls, we could select the risk strategy that reduces risk by at least 29% while minimizing cost. We can filter out strategies that do not meet the risk reduction requirement and rank the remaining combinations in ascending order of cost. In the proposed use case, there are 657 combinations of security controls that reduce risk by at least 29%. Table 11 shows the top five combinations in ascending order of cost.

As it can be observed from the table, these combinations have an excellent risk reduction and allow for a cost reduction of about 60% compared to the implementation of the comprehensive risk strategy. Results indicate that the exclusive implementation of non-technical security controls (e.g., customer satisfaction surveys) or technical controls (e.g., Malware Defenses) is not the best risk strategy to adopt. In fact, the combination of both kinds of security controls gives the best results in terms of performance.

It is also possible to make graphic considerations which help strike a balance between risk reduction percentage and related cost. Fig. 11 relates the normalized cost to the risk reduction percentage. Each point represents a subset of the implemented security controls. It is possible to observe that security controls can be grouped into five clusters based on a clearly identifiable range of risk reduction percentage. Depending on the selected range of risk reduction percentage, it is possible to select the risk strategy implementation with the lowest cost in the group. For the largest percentage of risk reduction (i.e., ~30%) the minimum normalized cost is 0.4, or, likewise, the total cost is reduced by 60%, as observed in the previous analysis. In contrast, the range that minimizes cost is the one that reduces the security risk by less than 5%. Therefore, when selecting the security risk strategy, it is crucial to find a compromise between risk reduction and implementation cost.

5.3. Security practitioner considerations

Cybersecurity risk management models aim to provide an accurate representation of a company, but they are susceptible to errors. One of

the main challenges lies in the uncertainty surrounding various factors, particularly those related to insiders. Consequently, our model may not fully capture the actual security risks faced by the company.

In this section, we provide guidance for security experts who wish to implement our model within their organizations. This guidance offers valuable insights into effectively incorporating our model into existing risk management processes.

5.3.1. Security controls costs and financial losses

In order to implement the model, it is essential to estimate the costs associated with security controls and the financial losses resulting from a cyber attack. The costs of security controls can generally be determined with relative certainty, as they involve hardware, software, services, and the expenses related to security teams, solution deployment, and maintenance.

On the other hand, estimating financial losses is often challenging and prone to inaccuracies. In Section 2.2.2, we propose an approach to estimate the financial loss per asset, drawing upon established formulae from existing literature. However, it is important to note that these formulae may not fully capture the actual financial losses experienced by the company. Certain costs can be estimated more accurately, such as the direct costs associated with system recovery, legal expenses, and the economic impact resulting from service disruptions. Simulations, such as backup recovery tests, can help estimate the cost of system recovery. However, there are other costs that are difficult to predict, such as the reputational damage leading to decreased sales and customer dissatisfaction following a data breach. Companies often employ business teams to develop forecasting models to monitor customer satisfaction and implement marketing strategies. These strategies may involve distributing customer questionnaires to gather feedback and enhance the quality of services. Cybersecurity experts can collaborate with these business teams to develop forecasting models that attempt to estimate the financial losses that would arise if a data breach affects customers' data. Gathering customers' feedback regarding the impacts of a data breach can be particularly valuable in forecasting financial losses.

In summary, it is crucial for security experts to work closely with business teams to enhance the accuracy of threat impact assessments and estimate financial losses more effectively.

5.3.2. Threats

Estimating threat probabilities is a common challenge in cybersecurity risk management processes. To address this, cybersecurity experts often employ multiple-choice surveys to assess the likelihood and/or impact of threats. These surveys are distributed among various groups within the company and provide either qualitative assessments (e.g., high, medium, low probability) or quantitative values (e.g., 10%, 25%) that can be used for risk assessment.

In the previous section, we suggested using the VERIS database to estimate threat probabilities. However, it is important to note that the information available in public data sources may not accurately reflect the specific situation of the company. Therefore, it is crucial for security experts to integrate public data with surveys conducted within the company to obtain estimations that are contextualized and tailored to the organization's specific circumstances. By combining external data sources with internal surveys, a more accurate assessment of threat probabilities can be achieved.

5.3.3. Insiders threats

The estimation of insider threats' parameters, such as human error and insiderness probability, poses significant challenges. Further research is needed to establish the link between human errors, insiderness, and security risks. In Section 6, we outline several future research directions in this regard.

However, security practitioners can begin adopting the framework through practical approaches. For addressing human errors, an effective approach is to implement established methodologies for predicting

human error rates. Examples of such methodologies include the Technique for Human Error-Rate Prediction (THERP), Cognitive Reliability and Error Analysis Method (CREAM), Technique for Human Error Assessment (THEA), Cause Based Decision Tree (CBDT), and others (Liu et al., 2021). Security experts can assess employees' tasks and determine if they involve security risks, and then implement the appropriate methodologies for specific personnel.

Insiderness is a particularly challenging parameter, and it will be thoroughly explored in future works. In particular, one relevant recent study by Greitzer et al. (2021) will be used as a basis for further research. As a practical approach, anonymous surveys can be conducted to analyze employees' satisfaction and estimate the psychological factors that influence insider threats. Surveys can be administered to each department within the company, and the insiderness properties can be grouped based on employees belonging to the same department, allowing for the estimation of the risk of malicious behaviors. However, the relationship between an insider's malicious behavior and attack triggers (as a function of psychological, social and behavioral factors) remains a subject of ongoing study.

5.3.4. Security controls

The parameter of security controls' threat probability reduction poses challenges in terms of precise definition. While several studies have attempted to define formulae, it is difficult to precisely quantify the effectiveness of security controls.

One approach to address this challenge is to conduct a security assessment with enabled security controls. For example, the effectiveness of a security training course can be evaluated by comparing the results of a phishing test conducted before and after the training. The difference in the number of compromised employees can indicate the effectiveness of the training course. Similarly, for antivirus and security monitoring solutions, simulated ransomware attacks and penetration tests can be conducted both with and without the controls enabled. The reduction in the occurrence of related threats can provide a percentage estimation of the controls' effectiveness.

It is important to note that these solutions may require significant costs and time investments, and careful consideration should be given to selecting the most appropriate methods based on the specific context and needs of the organization.

5.3.5. Cyclical feedback loop process to improve accuracy

After a security breach, it is crucial for companies to undergo a "learned experience" step where security experts thoroughly investigate the errors that led to the incident, analyze the effectiveness of security controls, and take steps to enhance the overall cybersecurity posture of the organization. This event provides an opportunity to review and refine all the parameters of the proposed framework.

Following a breach, the company can gather valuable information regarding inaccurate parameters such as indirect costs, human errors, and insiderness. This information can be used to adjust and fine-tune the parameters, resulting in more accurate risk values. The effectiveness of security controls and their reduction parameters can also be reevaluated and optimized. Additionally, the costs associated with implementing security controls can be assessed and made more efficient.

It is important to acknowledge that despite the suggestions provided in this section, there may still be limitations and inaccuracies, particularly when it comes to insider parameters. However, by continuously learning from security incidents and refining the framework, organizations can make progress in reducing the impact of inaccurate factors.

In Section 6, we present future research ideas that aim to further improve the framework and address the challenges related to parameter accuracy.

5.4. Considerations about time and space complexity

The proposed framework requires the inference computation on Bayesian Belief Network, that is known to be an NP-hard problem (Dagum and Luby, 1993). In this section, we show that it is possible to overcome the problem by adopting several criteria. Though, it is important to underline that the primary goal of this work is to describe the model. Hence, we will not herein discuss performance issues in detail. A scaling solution that implements the suggested optimization criteria will be proposed in future works.

5.4.1. Attack graph generation performance

To generate the attack graph we adapted MulVAL for the creation of the threat graph. Although MulVAL is extensively used in the research field (Tayouri et al., 2022), it is subject to several performance limitations.

Wang et al. (2019) underline that MulVAL cannot be used in large scale network environments. In our model the presence of a large number of employees and/or assets exponentially increases the graph generation time. A few optimization strategies can be leveraged in order to face this issue, as discussed below.

Several authors create algorithms that can be used to efficiently generate an attack graph (Ou et al., 2006; Chokshi et al., 2012; Albanese et al., 2012). In these works, authors propose algorithms that have polynomial complexity both in time and space. Though, such approaches should be thoroughly validated through solid experimental campaigns aimed at assessing their scalability in real-world complex scenarios.

Previous works are focused on the automatic generation of attack graphs from data sources, without considering potential performance issues. To the best of our knowledge, there is no study that explores such a challenging problem. In future works we intend to tackle this issue by investigating scalable approaches to the generation of attack graphs. To the purpose, state-of-the-art solutions will be both evaluated and integrated in our framework.

5.4.2. Bayesian complexity

To address the mentioned NP-hard problem, several authors propose model variations that effectively improve performance. Amongst the most promising proposals we find approximate inference algorithms, such as Loopy Belief Propagation (Murphy et al., 2013) or sampling inference (which uses sampling to compute the posterior probability). More recent works propose innovative approaches to address memory and time issues. Byun et al. (2019) propose a new matrix-based data structure for discrete Bayesian Networks that improves memory usage. Jongsawat and Premchaiswadi (2013) show that it is possible to compute an exact inference by leveraging the MapReduce programming model to run parts of the original network in parallel. Michiels et al. (2021) offer a public framework for learning Bayesian Networks that can scale to tens of thousands of nodes while providing fast and friendly user experience. These approaches can be integrated into our framework to model realistic use-cases with large networks. The existing exact Bayesian network inference algorithms share the property of run time exponentiality in the size of the largest clique of the triangulated moral graph, which is also called the induced width (i.e., the treewidth) of the graph (Corneil and Rotics, 2005). For this reason, it is crucial to find out criteria that reduce the treewidth of the network. We propose two criteria to reduce the network complexity.

Optimization Criterion 1. Use boolean assumptions to reduce model complexity.

In the use case we proposed above, several properties can be represented as boolean conditions. This is, e.g., the case of both “human error” and “insiderness”. These assumptions reduce the network complexity. Indeed, we do not have to compute the posterior probability

for these nodes, which can hence be removed from the network. Anyway, this approach might in some cases prove to be over simplistic and thus affect the realism of the model.

Optimization Criterion 2. Consider category classes instead of single elements.

In the proposed models the network complexity depends on the number of employees, assets and vulnerabilities. Instead of considering the total number of employees and assets, we might leverage the concept of ‘categories’. For employees, it would be possible to use company business areas, such as Human Resources (HR), Marketing, Research and Development (R&D). As to assets, it would be possible to categorize them by considering their importance in terms of key features like, e.g., the number of sensitive records associated with them.

The proposed optimization criterion should be applied by minimizing the difference between the posterior probability of the categorized model and that of the original one. In future works we will explore clustering techniques to define the optimal number of categories that minimize such an error.

5.4.3. Security controls and performance

Algorithm 1 iterates over an exponential number of security control combinations, therefore it is computationally expensive. However, each risk strategy performance computation of a single iteration is independent from the others. Therefore, it is possible to apply parallel computing techniques (Shukur et al., 2020) to increase performance. Another approach could be to store pre-computed risk strategy tables for specific threat models. Finally, one might think of applying machine learning techniques to infer the relationships between threat graphs, security controls and risk strategy. This is a fundamental issue for future research that needs to be further investigated.

5.4.4. Future evolutions of the model

According to the previous observations, future works will investigate state-of-the-art solutions and explore new techniques to:

- reduce time and space complexity for threat graph computation;
- reduce time and space complexity of the inference algorithms;
- explore the application of optimization criteria to reduce the treewidth of the threat graph;
- analyze parallel computing approaches to decrease the exponential complexity of Algorithm 1.

We plan to realize a framework able to overcome MulVAL’s limits in terms of time and space complexity. We also intend to explore the integration of state-of-the-art inference algorithms on Bayesian Belief Networks to reduce the complexity associated with inference computation. Finally, we will investigate if it is possible to adopt the proposed optimization criteria by minimizing the difference with respect to the posterior probabilities of the original model.

6. Conclusions

In this paper, we have presented a Risk Management framework based on Bayesian Networks to evaluate the risk associated with both internal and external threats. We have extended the work from Khosravi and Bafghi (2020) in order to include several types of threats not caused by security flaws. We have provided definitions that formalize the risk management process and demonstrated how it is possible to model an insider threat as a special type of attacker that can perform non-technical attacks, too. To define a risk strategy, we have used several types of security controls based on SANS CIS Critical Security Controls. We have underlined the importance of alternative defensive approaches, such as technical training sessions to reduce human error

and employee satisfaction surveys to decrease employees' disgruntlement. Finally, we have defined a performance indicator to select a risk strategy, i.e., a subset of implemented security controls that maximizes the security benefits while also minimizing the probability of goal threats. We have provided a use case scenario that shows an application example of the framework by using the VERIS set of metrics as a basis for the definition of the proposed threat model. Although the use case described in Section 5 is a simplistic representation of an IT system, it shows several aspects of our model. Future works will enrich the threat model and automate the generation of probabilities from the VERIS framework. Estimating threat probabilities by just relying on the security incidents contained within the VERIS framework can indeed bring to unreliable results. Hence, we envision to include other datasets in our framework, like, e.g., the one proposed by Abbiati et al. (2021), which integrates several datasets in order to provide statistically significant observations. Further works will extend the threat model and the list of security controls, by exploring alternative classification schemes. As repeatedly underlined herein before, the use of attack graphs offers a number of benefits. However, as MulVAL is based on first-order logic, it has a few intrinsic limitations for modeling complex scenarios. In fact, for such scenarios, the number of required rules grows exponentially. For this reason, we will investigate alternative approaches to model the attacker's behavior. For example, second-order and higher-order logic (Väänänen, 2021) might reduce the model's complexity through the utilization of either universal or existential quantifiers to model both threats and assets. In Section 4.6, we have defined the malicious insider and underlined that malicious insider attack paths could involve wider categories, such as supply-chain attacks. With the supply-chain, we can spot situations in which increased privileges do exist. Let's figure out, as an example, an external consultant who has access to a system on a customer's premises. It is in theory possible to generalise the currently adopted concept of "insiderness" by defining a generic "disgruntlement" property that enables critical threats against a system in case the disgruntled entity (either an internal or an external one) also holds increased privileges allowing them to carry out a successful attack. This is for sure among the concepts we will further explore in our future work. The threat impact evaluation defined in Equation (6) could also be subject to relevant improvements. In fact, we have used the logarithmic relationship between the number of records stored into an asset and the security incident losses. This relationship might be oversimplistic, as it does not consider several factors, like, e.g., the fact that different assets might contain records having different sensitivity and, consequently, different values. We are aware that this work is a preliminary step toward a complete Risk Management framework that includes insider threats. Further studies will need to be undertaken to refine the model. In Section 5.3, we have provided suggestions for security practitioners aiming at integrating our framework into their companies. Although companies could benefit from the framework, the prioritized risk strategies could not be optimal, as many factors required to run the algorithm may be inherently inaccurate. In order to address the issue, companies should monitor the frameworks' risk strategy outputs and fine-tune them according to their business needs. The framework could also benefit from well-known methodologies developed to manage the input uncertainty, such as sensitivity analysis (Saltelli, 2002). In future works, we will assess the framework through sensitivity analysis and Monte Carlo simulation and evaluate the impact of variables' uncertainty. We also intend to implement the framework in companies in order to obtain effective feedback from security risk management teams and thus improve the overall method.

The work lets several questions open. We ask ourselves whether is it possible to model the relationship between OCEAN's personal, social, behavioral traits and the insiderness property. Recent works provide comprehensive insider threats ontologies (Costa et al., 2016; Greitzer et al., 2018) that could be included in our model in order to enrich its expressiveness. Similarly, we wonder whether is it possible to find a reliable connection between human error probability and security tasks.

However, current datasets do not provide enough information to define these relationships properly. All this to say that the role of insider threats in risk management is still an unexplored field. We do hope that this work will offer useful insights to colleagues interested in investigating such a challenging research field.

CRedit authorship contribution statement

Nicola d'Ambrosio: Formal analysis, Methodology, Software, Validation, Visualization, Writing – review & editing. **Gaetano Perrone:** Conceptualization, Formal analysis, Methodology, Software, Validation, Visualization, Writing – original draft, Writing – review & editing. **Simon Pietro Romano:** Methodology, Project administration, Supervision, Writing – original draft, Writing – review & editing.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Data availability

Data are public available and I share the code and results through the GitHub platform.

Funding

This research did not receive any specific grant from funding agencies in the public, commercial, or not-for-profit sectors.

References

- Abbiati, G., Ranise, S., Schizzerotto, A., Siena, A., 2021. Merging datasets of CyberSecurity incidents for fun and insight. *Front. Big Data* 3. <https://doi.org/10.3389/fdata.2020.521132>.
- Advisen, 2019. <https://www.advisenltd.com/data/cyber-loss-data/>. (Accessed 28 April 2021).
- Al-Mhiqani, M.N., Ahmad, R., Abidin, Z.Z., Yassin, W., Hassan, A., Abdulkareem, K.H., Ali, N.S., Yunus, Z., 2020. A review of insider threat detection: classification, machine learning techniques, datasets, open challenges, and recommendations. *Appl. Sci.* 10 (15), 5208. <https://doi.org/10.3390/app10155208>.
- Albanese, M., Jajodia, S., Noel, S., 2012. Time-efficient and cost-effective network hardening using attack graphs. In: *IEEE/IFIP International Conference on Dependable Systems and Networks (DSN 2012)*, pp. 1–12.
- Ammann, P., Wijesekera, D., Kaushik, S., 2002. Scalable, graph-based network vulnerability analysis. In: *Proceedings of the 9th ACM Conference on Computer and Communications Security, CCS '02. Association for Computing Machinery, New York, NY, USA*, pp. 217–224.
- Auricchio, N., Cappuccio, A., Caturano, F., Perrone, G., Romano, S.P., 2022. An automated approach to web offensive security. *Comput. Commun.* 195, 248–261. <https://doi.org/10.1016/j.comcom.2022.08.018>.
- Axelrad, E.T., Sticha, P.J., Brdiczka, O., Shen, J., 2013. A Bayesian network model for predicting insider threats. In: *2013 IEEE Security and Privacy Workshops*, pp. 82–89.
- Behbehani, D., Rajarajan, M., Komninos, N., Al-Begain, K., 2022. Detecting open banking api security threats using Bayesian attack graphs. In: *2022 14th International Conference on Computational Intelligence and Communication Networks (CICN)*, pp. 789–796.
- Bishop, M., Engle, S., Frincke, D.A., Gates, C., Greitzer, F.L., Peisert, S., Whalen, S., 2010. A risk management approach to the "insider threat". In: *Insider Threats in Cyber Security*. Springer US, pp. 115–137.
- Bjarnar, 2021. The cost of outsourcing an employee survey. <https://www.driveresearch.com/market-research-company-blog/the-cost-of-outsourcing-an-employee-survey/>, online; 10-Apr-2022.
- Byun, J.-E., Zwirgmaier, K., Straub, D., Song, J., 2019. Matrix-based Bayesian network for efficient memory storage and flexible inference. *Reliab. Eng. Syst. Saf.* 185, 533–545. <https://doi.org/10.1016/j.res.2019.01.007>.
- Cappelli, D.M., Moore, A.P., Trzeciak, R.F., 2012. *The CERT Guide to Insider Threats: How to Prevent, Detect, and Respond to Information Technology Crimes (Theft, Sabotage, Fraud)*. Addison-Wesley.
- Ceri, S., Gottlob, G., Tanca, L., 1989. What you always wanted to know about datalog (and never dared to ask). *IEEE Trans. Knowl. Data Eng.* 1 (1), 146–166. <https://doi.org/10.1109/69.43410>.

- Chan, S.H., Yao, L.J., 2005. An empirical investigation of hacking behavior. *Rev. Bus. Inf. Syst. (RBIS)* 9 (4), 41–58. <https://doi.org/10.19030/rbis.v9i4.4443>.
- Chokshi, I., Ghosh, N., Ghosh, S.K., 2012. Efficient generation of exploit dependency graph by customized attack modeling technique. In: 2012 18th International Conference on Advanced Computing and Communications (ADCOM), pp. 39–45.
- Corneil, D.G., Rotics, U., 2005. On the relationship between clique-width and treewidth. *SIAM J. Comput.* 34 (4), 825–847. <https://doi.org/10.1137/s0097539701385351>.
- Costa, D., Albrethsen, M., Collins, M., Perl, S., Silowash, G., Spooner, D., 2016. An insider threat indicator ontology. Tech. Rep. CMU/SEI-2016-TR-007, Software Engineering Institute, Carnegie Mellon University, Pittsburgh, PA. <http://resources.sei.cmu.edu/library/asset-view.cfm?AssetID=454613>.
- Coursera, 2022. Cybersecurity analyst salary guide: how much can you make? <https://www.coursera.org/articles/cybersecurity-analyst-salary>, online; 10-Apr-2022.
- Cyentia, 2020. Information risk insights study. Tech. rep. Cyentia Institute.
- Dagum, P., Luby, M., 1993. Approximating probabilistic inference in Bayesian belief networks is NP-hard. *Artif. Intell.* 60 (1), 141–153. [https://doi.org/10.1016/0004-3702\(93\)90036-b](https://doi.org/10.1016/0004-3702(93)90036-b).
- Data, P., 2021. How much does cyber security cost? Common cyber security expenses & fees. <https://www.provendatarecovery.com/blog/cyber-security-cost-expenses-fees/>, online; 10-Apr-2022.
- Deng, S., Zhang, J., Wu, D., He, Y., Xie, X., Wu, X., 2023. A quantitative risk assessment model for distribution cyber-physical system under cyberattack. *IEEE Trans. Ind. Inform.* 19 (3), 2899–2908. <https://doi.org/10.1109/tii.2022.3169456>.
- Doran, G.T., 2008. There's a s.m.a.r.t. way to write management's goals and objectives. <https://community.mis.temple.edu/mis0855002fall2015/files/2015/10/S.M.A.R.T-Way-Management-Review.pdf>, online; 25-Apr-2022.
- Ducamp, G., Gonzales, C., 2020. Wuillemin, agrum/pyagrum: a toolbox to build models and algorithms for probabilistic graphical models in python. In: Jaeger, M., Nielsen, T.D. (Eds.), *Proceedings of the 10th International Conference on Probabilistic Graphical Models*. In: *Proceedings of Machine Learning Research*, PMLR, vol. 138, pp. 609–612. <https://proceedings.mlr.press/v138/ducamp20a.html>.
- Erola, A., Agrafiotis, I., Nurse, J.R., Axon, L., Goldsmith, M., Creese, S., 2022. A system to calculate cyber value-at-risk. *Comput. Secur.* 113, 102545. <https://doi.org/10.1016/j.cose.2021.102545>.
- Frigault, M., Wang, L., 2008. Measuring network security using Bayesian network-based attack graphs. In: 2008 32nd Annual IEEE International Computer Software and Applications Conference, pp. 698–703.
- Ghazo, A.T.A., Ibrahim, M., Ren, H., Kumar, R., 2020. A2g2v: automatic attack graph generation and visualization and its applications to computer and SCADA networks. *IEEE Trans. Syst. Man Cybern. Syst.* 50 (10), 3488–3498. <https://doi.org/10.1109/tsmc.2019.2915940>.
- Greitzer, F., Purl, J., Leong, Y.M., Becker, D.S., 2018. Sofit: sociotechnical and organizational factors for insider threat. In: 2018 IEEE Security and Privacy Workshops (SPW), pp. 197–206.
- Greitzer, F.L., 2019. Insider threats. In: *Proceedings of the Northwest Cybersecurity Symposium*. ACM, pp. 1–8.
- Greitzer, F.L., Purl, J., Sticha, P.J., Martin, C.Y., Lee, J.D., 2021. Use of expert judgments to inform Bayesian models of insider threat risk. *J. Wirel. Mob. Netw. Ubiquitous Comput. Dependable Appl.* 12 (2), 3–47. <https://doi.org/10.22667/JOWUA.2021.06.30.003>.
- Gx1, Nda994, Ns-unina/insiderthreats, 2022. <https://doi.org/10.5281/ZENODO.6471205>. <https://zenodo.org/record/6471205>.
- Holroyd, C.B., Coles, M.G.H., 2002. The neural basis of human error processing: reinforcement learning, dopamine, and the error-related negativity. *Psychol. Rev.* 109 (4), 679–709. <https://doi.org/10.1037/0033-295x.109.4.679>.
- Jacob, 2014. Analyzing ponemon cost of data breach. <https://datadrivensecurity.info/blog/posts/2014/Dec/ponemon/>, online; 10-Apr-2022.
- Jajodia, S., Noel, S., O'Berry, B., 2005. Topological analysis of network attack vulnerability. Springer US, Boston, MA, pp. 247–266.
- Jongsawat, N., Premchaiswadi, W., 2013. Solving the NP-hard computational problem in Bayesian networks using apache hadoop MapReduce. In: 2013 Eleventh International Conference on ICT and Knowledge Engineering. IEEE, pp. 1–5.
- Joshi, C., Aliaga, J.R., Insua, D.R., 2021. Insider threat modeling: an adversarial risk analysis approach. *IEEE Trans. Inf. Forensics Secur.* 16, 1131–1142. <https://doi.org/10.1109/TIFS.2021.3118886>.
- Kammuller, F., Probst, C.W., 2017. Modeling and verification of insider threats using logical analysis. *IEEE Syst. J.* 11 (2), 534–545. <https://doi.org/10.1109/jsyst.2015.2453215>.
- Kappala, M., 2015. *Employee Satisfaction Survey*. LAP Lambert Academic Publishing.
- Kaynar, K., 2016. A taxonomy for attack graph generation and usage in network security. *J. Inf. Secur. Appl.* 29, 27–56. <https://doi.org/10.1016/j.jisa.2016.02.001>.
- Khosravi-Farmad, M., Ghaemi-Bafghi, A., 2020. Bayesian decision network-based security risk management framework. *J. Netw. Syst. Manag.* 28 (4), 1794–1819. <https://doi.org/10.1007/s10922-020-09558-5>.
- Kritzing, D., 2017. Fault tree analysis. In: *Aircraft System Safety*. Elsevier, pp. 59–99.
- Kweon, E., Lee, H., Chai, S., Yoo, K., 2019. The utility of information security training and education on cybersecurity incidents: an empirical evidence. *Inf. Syst. Front.* <https://doi.org/10.1007/s10796-019-09977-z>.
- Lallie, H.S., Debattista, K., Bal, J., 2018. An empirical evaluation of the effectiveness of attack graphs and fault trees in cyber-attack perception. *IEEE Trans. Inf. Forensics Secur.* 13 (5), 1110–1122. <https://doi.org/10.1109/tifs.2017.2771238>.
- Lallie, H.S., Debattista, K., Bal, J., 2020. A review of attack graph and attack tree visual syntax in cyber security. *Comput. Sci. Rev.* 35, 100219. <https://doi.org/10.1016/j.cosrev.2019.100219>.
- Levy, A., 2010. Information in biology: a fictionalist account. *Noûs* 45 (4), 640–657. <https://doi.org/10.1111/j.1468-0068.2010.00792.x>.
- Lindauer, B., 2020. Insider threat test dataset. <https://doi.org/10.1184/R1/12841247.V1>.
- Liu, P., Zhang, R., Yin, Z., Li, Z., 2021. Human Errors and Human Reliability. John Wiley and Sons, Ltd, pp. 514–572. Ch. 20. <https://onlinelibrary.wiley.com/doi/pdf/10.1002/9781119636113.ch20>. <https://onlinelibrary.wiley.com/doi/abs/10.1002/9781119636113.ch20>.
- Logan, P.Y., Clarkson, A.C., 2020. Enhancing information security: a qualitative risk analysis method for overcoming the insider threat. In: *Modern Organizations Through Information Technology*.
- Magklaras, G., Furnell, S., Brooke, P., 2006. Towards an insider threat prediction specification language. *Inf. Manag. Comput. Secur.* 14 (4), 361–381. <https://doi.org/10.1108/09685220610690826>.
- Martinez-Moyano, I.J., Rich, E., Conrad, S., Andersen, D.F., Stewart, T.R., 2008. A behavioral theory of insider-threat risks: a system dynamics approach. *ACM Trans. Model. Comput. Simul.* 18 (2). <https://doi.org/10.1145/1346325.1346328>.
- Mathew, S., Upadhyaya, S., Ha, D., Ngo, H.Q., 2008. Insider abuse comprehension through capability acquisition graphs. In: 2008 11th International Conference on Information Fusion, pp. 1–8.
- Michiels, M., Larrañaga, P., Bielza, C., 2021. Bayesuites: an open web framework for massive Bayesian networks focused on neuroscience. *Neurocomputing* 428, 166–181. <https://doi.org/10.1016/j.neucom.2020.11.066>. <https://www.sciencedirect.com/science/article/pii/S0925231220318609>.
- Munoz-Gonzalez, L., Sgandurra, D., Barrere, M., Lupu, E.C., 2019. Exact inference techniques for the analysis of Bayesian attack graphs. *IEEE Trans. Dependable Secure Comput.* 16 (2), 231–244. <https://doi.org/10.1109/tdsc.2016.2627033>.
- Munshi, A., Dell, P., Armstrong, H., 2012. Insider threat behavior factors: a comparison of theory with reported incidents. In: 2012 45th Hawaii International Conference on System Sciences, pp. 2402–2411.
- Murphy, K., Weiss, Y., Jordan, M.I., 2013. Loopy belief propagation for approximate inference: an empirical study. <https://doi.org/10.48550/ARXIV.1301.6725>. <https://arxiv.org/abs/1301.6725>, 2013.
- National vulnerability database, 2022. <https://nvd.nist.gov/>. (Accessed 9 March 2022).
- Nurse, J.R.C., Buckley, O., Legg, P.A., Goldsmith, M., Creese, S., Wright, G.R.T., Whitty, M., 2014. Understanding insider threat: a framework for characterising attacks. In: 2014 IEEE Security and Privacy Workshops. IEEE, pp. 214–228.
- NVD, 2021a. Cve-2021-41773. <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-41773>, online; 17-Apr-2023.
- NVD, 2021b. Cve-2021-44228. <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-44228>, online; 17-Apr-2023.
- Ou, X., Govindavajhala, S., Appel, A.W., 2005. MulVAL: a logic-based network security analyzer. In: 14th USENIX Security Symposium (USENIX Security 05), SSYM'05. USENIX Association, p. 8.
- Ou, X., Boyer, W.F., McQueen, M.A., 2006. A scalable approach to attack graph generation. In: *Proceedings of the 13th ACM Conference on Computer and Communications Security, CCS '06*. Association for Computing Machinery, New York, NY, USA, pp. 336–345.
- Palsson, K., Gudmundsson, S., Shetty, S., 2020. Analysis of the impact of cyber events for cyber insurance. *Geneva Pap. Risk Insur., Issues Pract.* 45 (4), 564–579. <https://doi.org/10.1057/s41288-020-00171-w>.
- Pearl, J., 1988. *Probabilistic Reasoning in Intelligent Systems: Networks of Plausible Inference*. Morgan Kaufmann Publishers Inc., San Francisco, CA, USA.
- Phillips, C., Swiler, L.P., 1998. A graph-based system for network-vulnerability analysis. In: *Proceedings of the 1998 Workshop on New Security Paradigms, NSPW '98*. Association for Computing Machinery, New York, NY, USA, pp. 71–79.
- Poolsappasit, N., Dewri, R., Ray, I., 2012. Dynamic security risk management using Bayesian attack graphs. *IEEE Trans. Dependable Secure Comput.* 9 (1), 61–74. <https://doi.org/10.1109/tdsc.2011.34>.
- Popovic, B., Radojka, M., Paunović, T., 2015. Employee satisfaction survey in function of business improvement. *Manag. - J. Theory Pract. Manag.* 20, 31–40. <https://doi.org/10.7595/management.fon.2015.0021>.
- Reason, J., 2000. Human error: models and management. *BMJ* 320 (7237), 768–770. <https://doi.org/10.1136/bmj.320.7237.768>.
- Roll, L.C., Ling, S., O., Li, S.Y., Witte, H.D., 2019. Human error: the impact of job insecurity on attention-related cognitive errors and error detection. *Int. J. Environ. Res. Public Health* 16 (13), 2427. <https://doi.org/10.3390/ijerph16132427>.
- Ross, R., 1916. An application of the theory of probabilities to the study of a priori pathometry.—part i. *Proc. R. Soc. Lond. Ser. A, Contain. Pap. Math. Phys. Character* 92 (638), 204–230. <https://doi.org/10.1098/rspa.1916.0007>. <https://royalsocietypublishing.org/doi/abs/10.1098/rspa.1916.0007>.
- Rothmann, S., Coetzer, E.P., 2003. The big five personality dimensions and job performance. *SA J. Ind. Psychol.* 29 (1). <https://doi.org/10.4102/sajip.v29i1.88>.
- Saito, Y., Anuardi, M.N.A.M., Matsubara, R., Sugaya, M., 2021. Preliminary analysis of human error prediction model by using biological information. In: *Engineering Psychology and Cognitive Ergonomics*. Springer International Publishing, pp. 324–335.
- Saltelli, A., 2002. Sensitivity analysis for importance assessment. *Risk Anal.* 22 (3), 579–590. <https://doi.org/10.1111/0272-4332.00040>.

- SANS, 2008. About sans institute. <https://www.sans.org/about/?msc=main-nav>, online; 15-Apr-2023.
- SANS, 2021. The cis critical security controls, version 8. <https://www.cisecurity.org/controls/v8>, online; 07-Apr-2022.
- Sarkar, K.R., 2010. Assessing insider threats to information security using technical, behavioural and organisational measures. *Inf. Secur. Tech. Rep.* 15 (3), 112–133. <https://doi.org/10.1016/j.istr.2010.11.002>.
- Sawilla, R.E., Ou, X., 2008. Identifying critical attack assets in dependency attack graphs. In: *Computer Security - ESORICS 2008*. Springer, Berlin Heidelberg, pp. 18–34.
- Shukur, H., Zeebaree, S.R.M., Ahmed, A.J., Zebari, R.R., Ahmed, O., Tahir, B.S.A., Sadeeq, M.A.M., 2020. A state of art survey for concurrent computation and clustering of parallel computing for distributed systems. *J. Appl. Sci. Technol. Trends* 1 (4), 148–154. <https://doi.org/10.38094/jastt1466>.
- Stone, A.G., 2021. The role risk-management plays in reducing insider threat's in the federal government. *Inf. Secur. J.: Glob. Perspect.*, 1–8. <https://doi.org/10.1080/19393555.2021.1998735>.
- Tayouri, D., Baum, N., Shabtai, A., Puzis, R., 2022. A survey of mulval extensions and their attack scenarios coverage. <https://doi.org/10.48550/ARXIV.2208.05750>. <https://arxiv.org/abs/2208.05750>, 2022.
- The veris framework, 2022. <https://veriscommunity.net/>. (Accessed 9 April 2022).
- TrustNet, 2022. Security awareness training cost. <https://www.trustnetinc.com/security-awareness-training/>, online; 10-Apr-2022.
- Tuor, A., Kaplan, S., Hutchinson, B., Nichols, N., Robinson, S., 2017. Deep learning for unsupervised insider threat detection in structured cybersecurity data streams. <https://doi.org/10.48550/ARXIV.1710.00811>.
- Väänänen, J., 2021. Second-order and higher-order logic. In: Zalta, E.N. (Ed.), *The Stanford Encyclopedia of Philosophy*, Fall 2021 edition. Metaphysics Research Lab, Stanford University.
- Veris csv database, 2008. <https://github.com/vz-risk/Vcdb/blob/master/data/csv/vcdb.csv.zip>, online; 9-Apr-2022.
- Verizon, 2021. 2021 data breach investigations report, online; 01-Jan-2022.
- Viegas, V., Kuyucu, O., 2022. Security metrics. In: *IT Security Controls*. Apress, pp. 221–244.
- Vincent, M.J., Herzberg, F., Mausner, B., Snyderman, B.B., 1960. The motivation to work. *Am. Sociol. Rev.* 25 (2), 288. <https://doi.org/10.2307/2092643>.
- Wang, C., Li, K., Tian, Y., He, X., 2019. Network risk assessment based on improved MulVAL framework and HMM. In: *Lecture Notes of the Institute for Computer Sciences, Social Informatics and Telecommunications Engineering*. Springer International Publishing, pp. 298–307.
- Wang, L., Noel, S., Jajodia, S., 2006. Minimum-cost network hardening using attack graphs. *Comput. Commun.* 29 (18), 3812–3824. <https://doi.org/10.1016/j.comcom.2006.06.018>.
- Warren, M., Hutchinson, W., 2000. Cyber attacks against supply chain management systems: a short note. *Int. J. Phys. Distrib. Logist. Manag.* 30 (7/8), 710–716. <https://doi.org/10.1108/09600030010346521>.
- Wing, J., 1990. A specifier's introduction to formal methods. *Computer* 23 (9), 8–22. <https://doi.org/10.1109/2.58215>.
- Wong, K., Chan, A.H.S., Ngan, S.C., 2019. The effect of long working hours and overtime on occupational health: a meta-analysis of evidence from 1998 to 2018. *Int. J. Environ. Res. Public Health* 16 (12), 2102. <https://doi.org/10.3390/ijerph16122102>.
- Xiong, W., Lagerström, R., 2019. Threat modeling – a systematic literature review. *Comput. Secur.* 84, 53–69.
- Yazdanparast, R., Hamid, M., Azadeh, M.A., Keramati, A., 2018. An intelligent algorithm for optimization of resource allocation problem by considering human error in an emergency department. *Int. J. Ind. Syst. Eng.* 11, 287–309.
- Yuan, F., Cao, Y., Shang, Y., Liu, Y., Tan, J., Fang, B., 2018. Insider threat detection with deep neural network. In: *Lecture Notes in Computer Science*. Springer International Publishing, pp. 43–54.
- Zenitani, K., 2023. Attack graph analysis: an explanatory guide. *Comput. Secur.* 126, 103081. <https://doi.org/10.1016/j.cose.2022.103081>.
- Zhang, C., Wang, S., Zhan, D., Yu, T., Wang, T., Yin, M., 2021. Detecting insider threat from behavioral logs based on ensemble and self-supervised learning. *Secur. Commun. Netw.* 2021, 1–11. <https://doi.org/10.1155/2021/4148441>.



Gaetano Perrone is currently CTO at SEcURITY Solutions for Innovation (SECSI), a company based in Naples focused on researching innovative solutions in the network security domain. Passionate in any area related to network security, cloud computing, and software development, he completed a Ph.D. degree in computer engineering and systems from the University of Naples in 2022. He continues conducting research in fuzzing, knowledge graph, and reinforcement learning domains to automate, formalize and increase the effectiveness of security testing approaches.



Simon Pietro Romano (Member, IEEE) is currently a Professor with the Department of Electrical Engineering and Information Technology, University of Napoli Federico II. He teaches computer networks, computer architectures, network security, and telematics applications. He is also the Co-Founder of Meetecho, a startup and university spin-off dealing with scalable video streaming and WebRTC-based unified collaboration, as well as of SEcURITY Solutions for Innovation (SECSI) that focuses on network security. He actively participates in Internet Engineering Task Force (IETF) standardization activities, mainly in the applications and real time (ART) area. (Based on document published on 10 November 2020.)



Nicola d'Ambrosio is currently an Ph.D. student at the Department of Electrical Engineering and Information Technology, University of Napoli Federico II. He worked as free-lance infrastructural penetration testing with SecSI, a startup and university spin-off that focuses on network security. He was also a tutor for Cyber HackAdemy, a professional cybersecurity course.